

云原生安全发展趋势及标准解读

陈屹力

中国信通院云大所云计算部副主任

2021首届-西部云安全峰会
Western China Cloud Security Summit 2021





陈屹力 中国信息通信研究院云大所云计算部副主任，云原生产业联盟秘书长，云计算开源产业联盟可信云工作组组长；主要从事云计算领域产业发展、关键技术研究、标准制定等相关工作，牵头撰写云计算行业20余个标准，曾荣获通信学会科技进步奖。

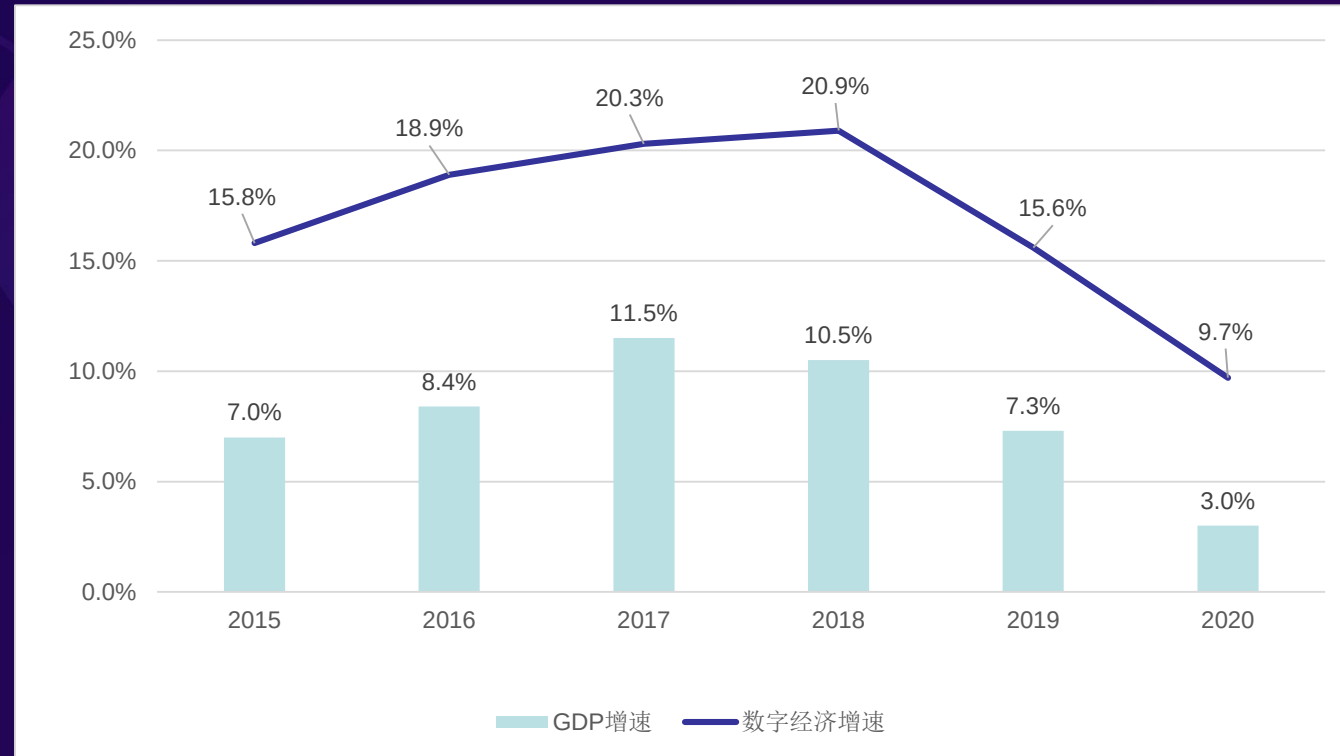
- 1 云计算进入全面云原生时代
- 2 云原生安全威胁全面显现
- 3 构建自底向上的云原生安全防护体系
- 4 云原生安全发展趋势
- 5 云原生安全成熟度标准体系

数字经济领跑GDP，产业数字化成为主要发力点

2020年，我国数字经济依然保持9.7%的高位增长，**远高于同期GDP名义增速约6.7个百分点**。数字经济成为推动国民经济持续稳定增长的关键动力。

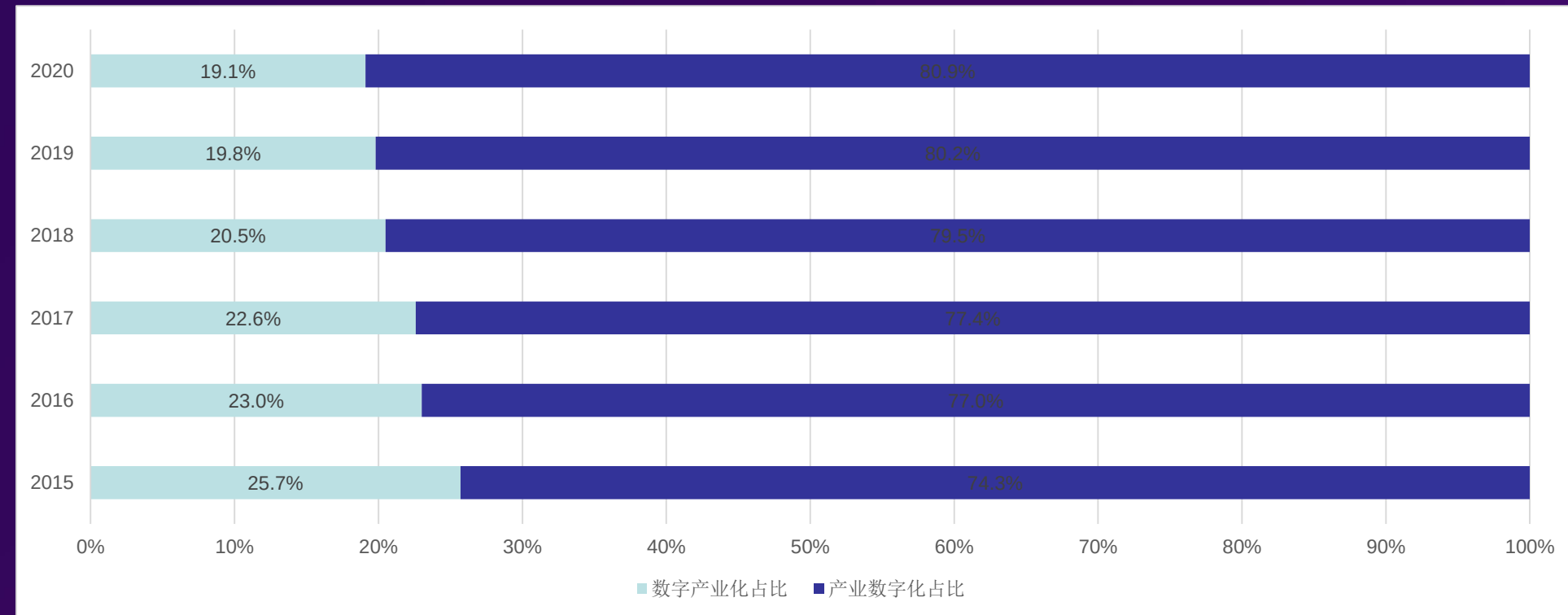
数字经济内部结构中**产业数字化的主导地位进一步巩固**。产业数字化深入发展获得新机遇，电子商务、平台经济、共享经济等数字化新模式接替涌现。

我国数字经济增速与GDP增速



数据来源：中国信息通信研究院《中国数字经济发展白皮书》

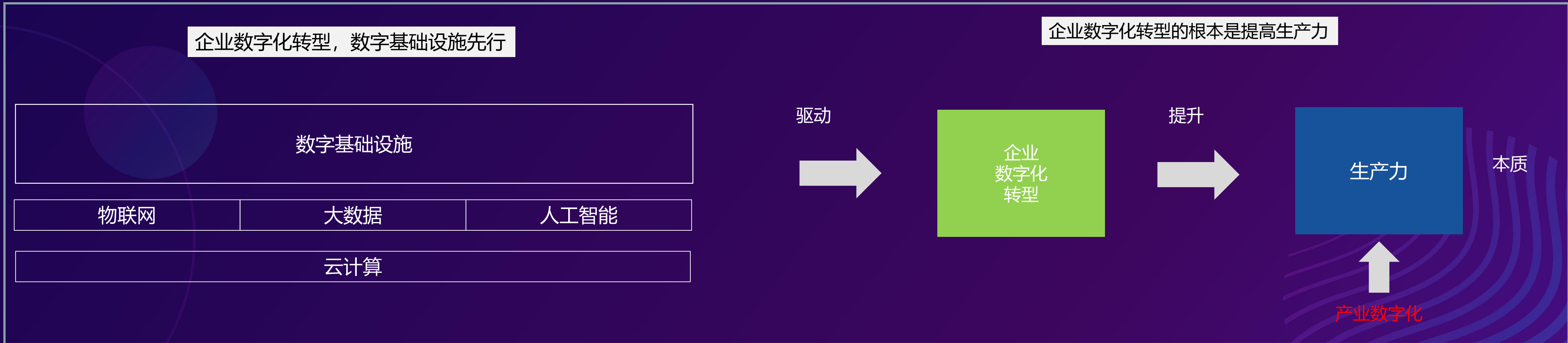
我国数字经济内部结构



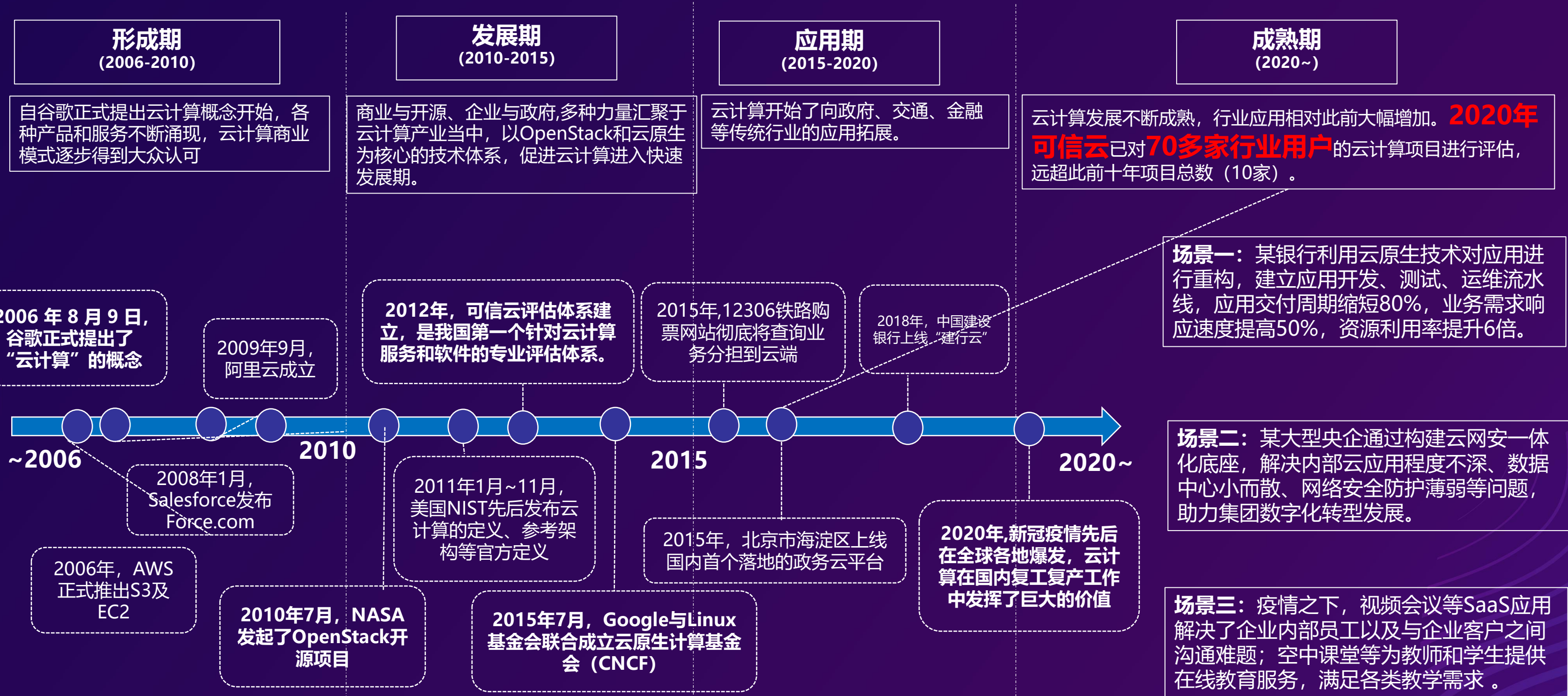
数据来源：中国信息通信研究院《中国数字经济发展白皮书》

数字基础设施是数字化转型的重要支撑

- **企业数字化转型** 是指企业与数字技术全面融合，提升效率的经济转型过程，即利用数字技术，把企业各要素、各环节全部数字化，推动技术、业务、人才、资本等要素资源配置优化，推动业务流程、生产方式重组变革，从而提高企业经济效率。
- **数字基础设施** 是指企业各项活动相关的数字化技术体系，用人工智能、大数据、云计算、物联网等新一代数字技术改造企业信息技术相关的基础软硬件，包括网络、数据中心、数字化平台、基础软件、IT工具软件等多层次基础IT能力。



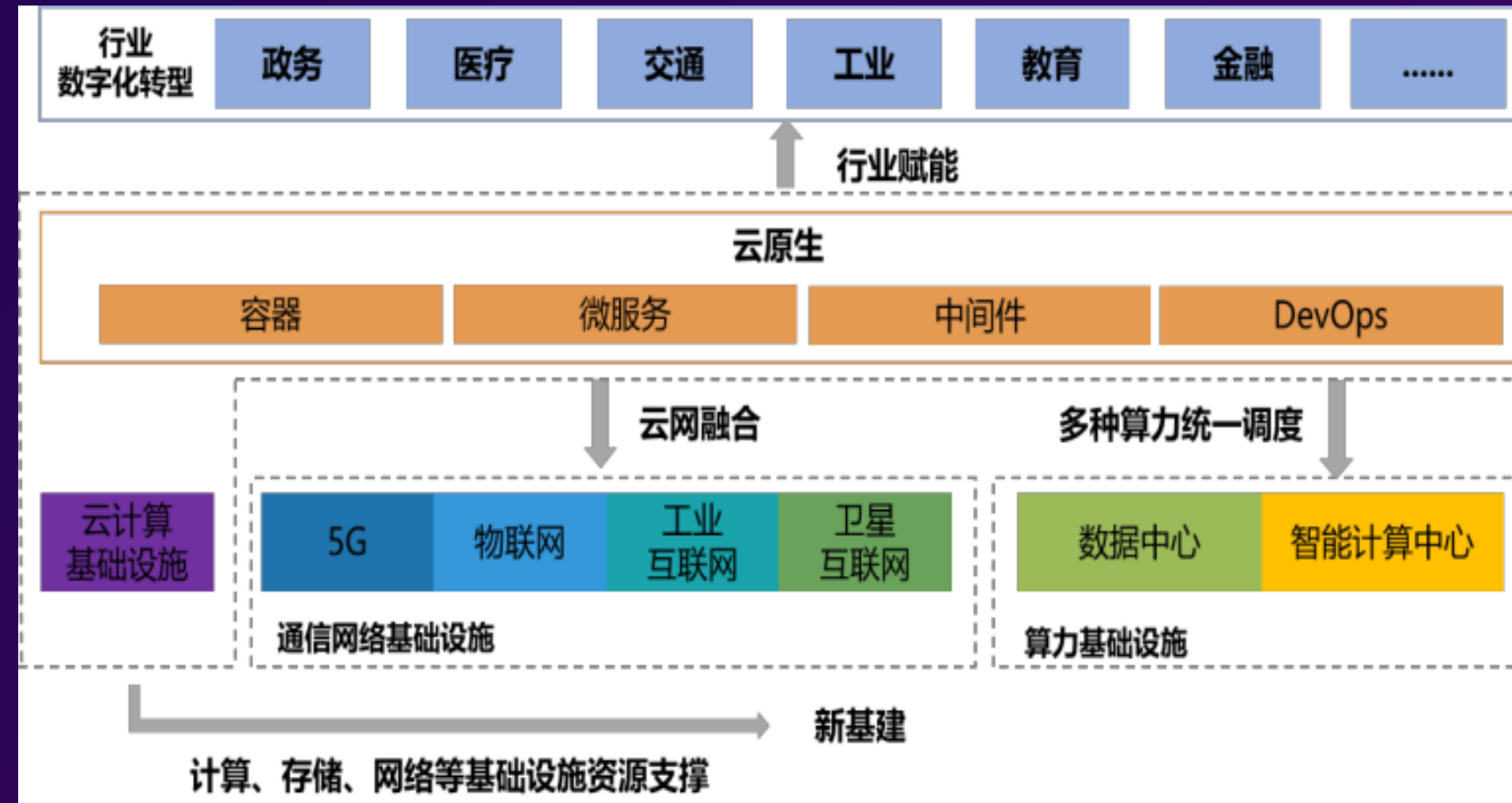
云计算发展日益成熟，逐步迈入深水区



云原生是数字基础设施的技术“内核”

- 数字基础设施能够有效整合资源，实现数字化基础设施能力的组件化、模块化封装，为企业业务创新提供高效、低成本的一体化服务支撑，满足海量多样化客户群体的个性化需求。
- 云计算以资源虚拟化为底层基础，以云原生为技术“内核”，构建全域数据高速互联与算力全覆盖的整体架构，成为传统行业基础设施云数智融合发展的重要基石。

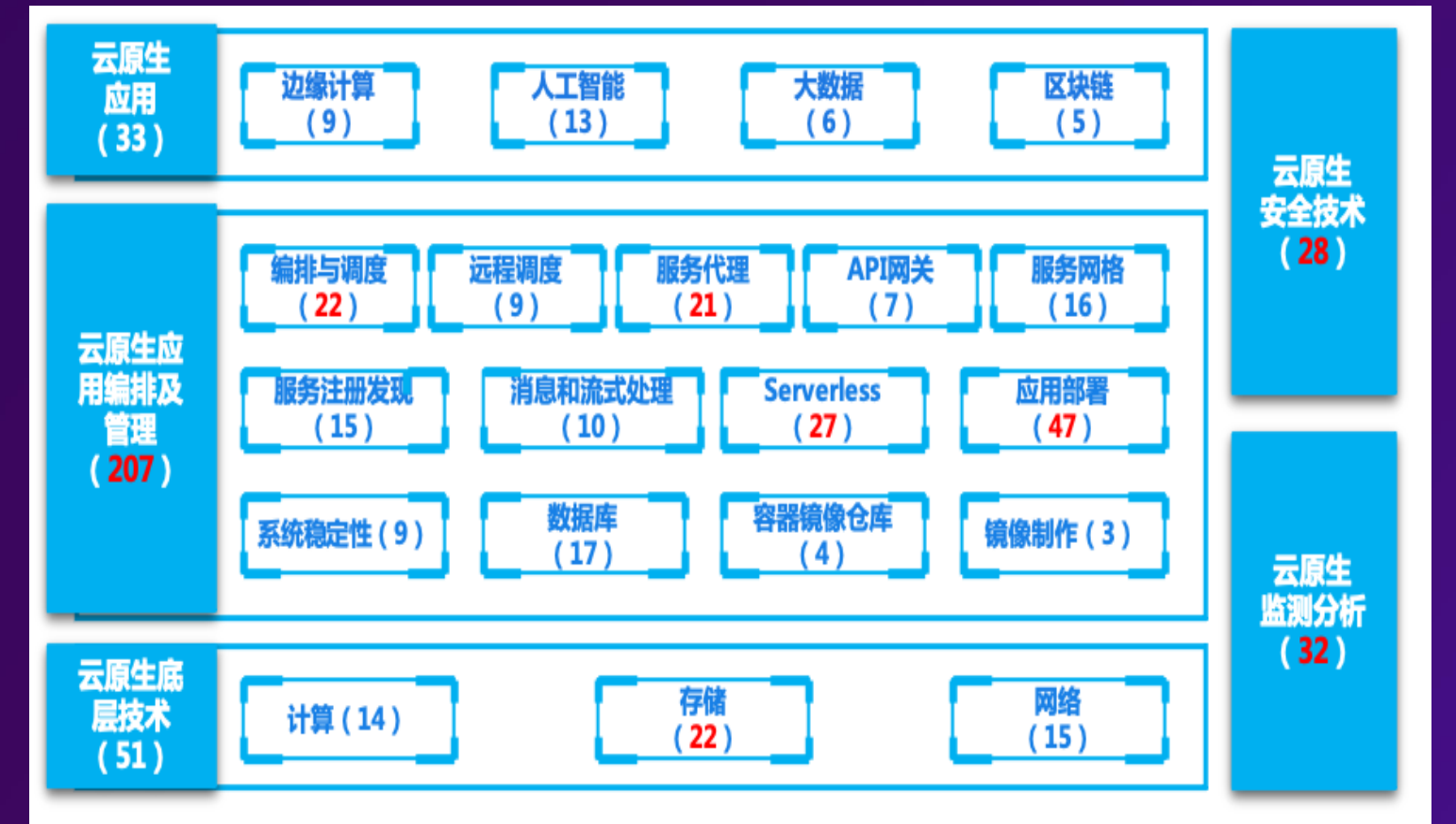
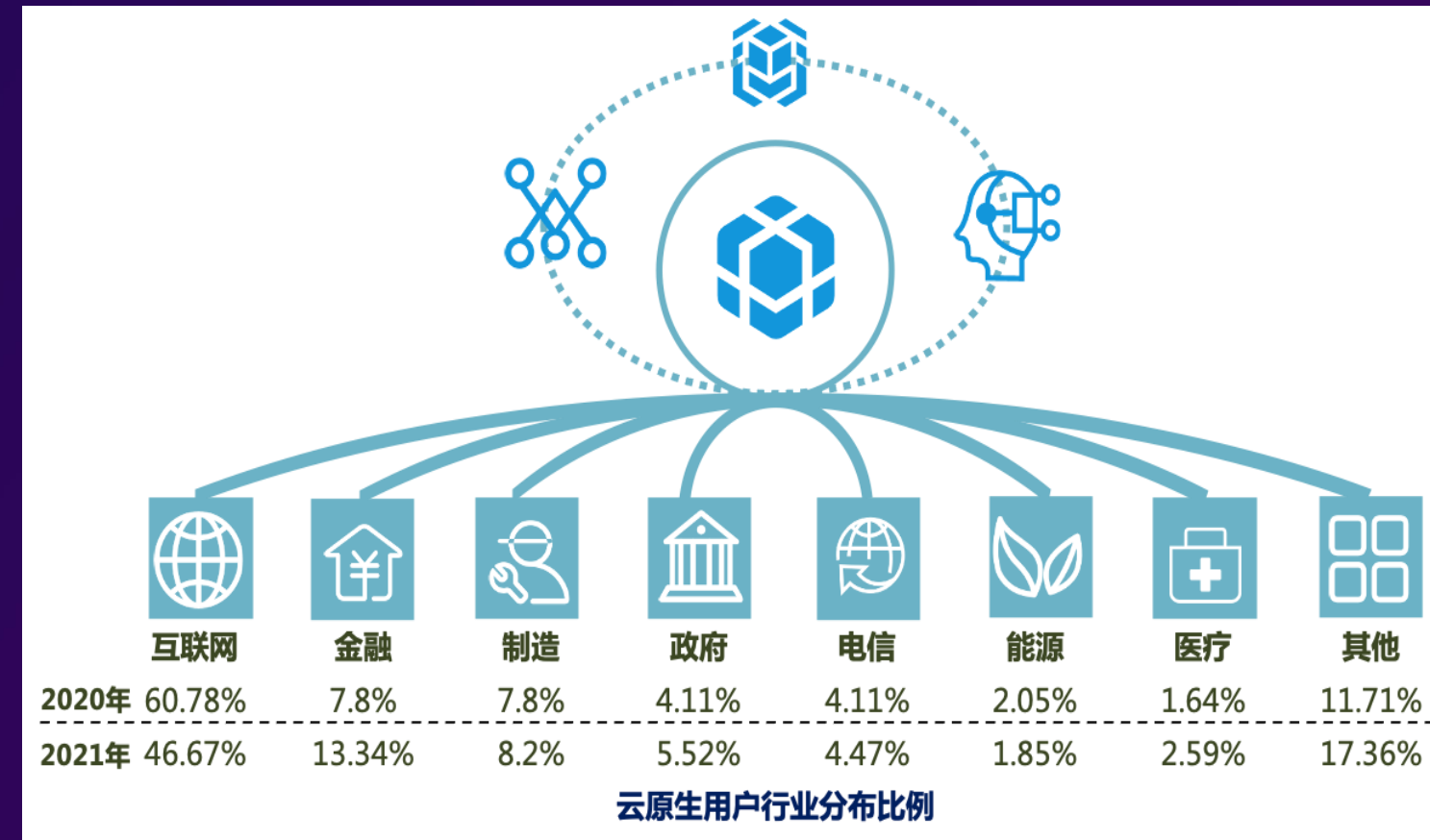
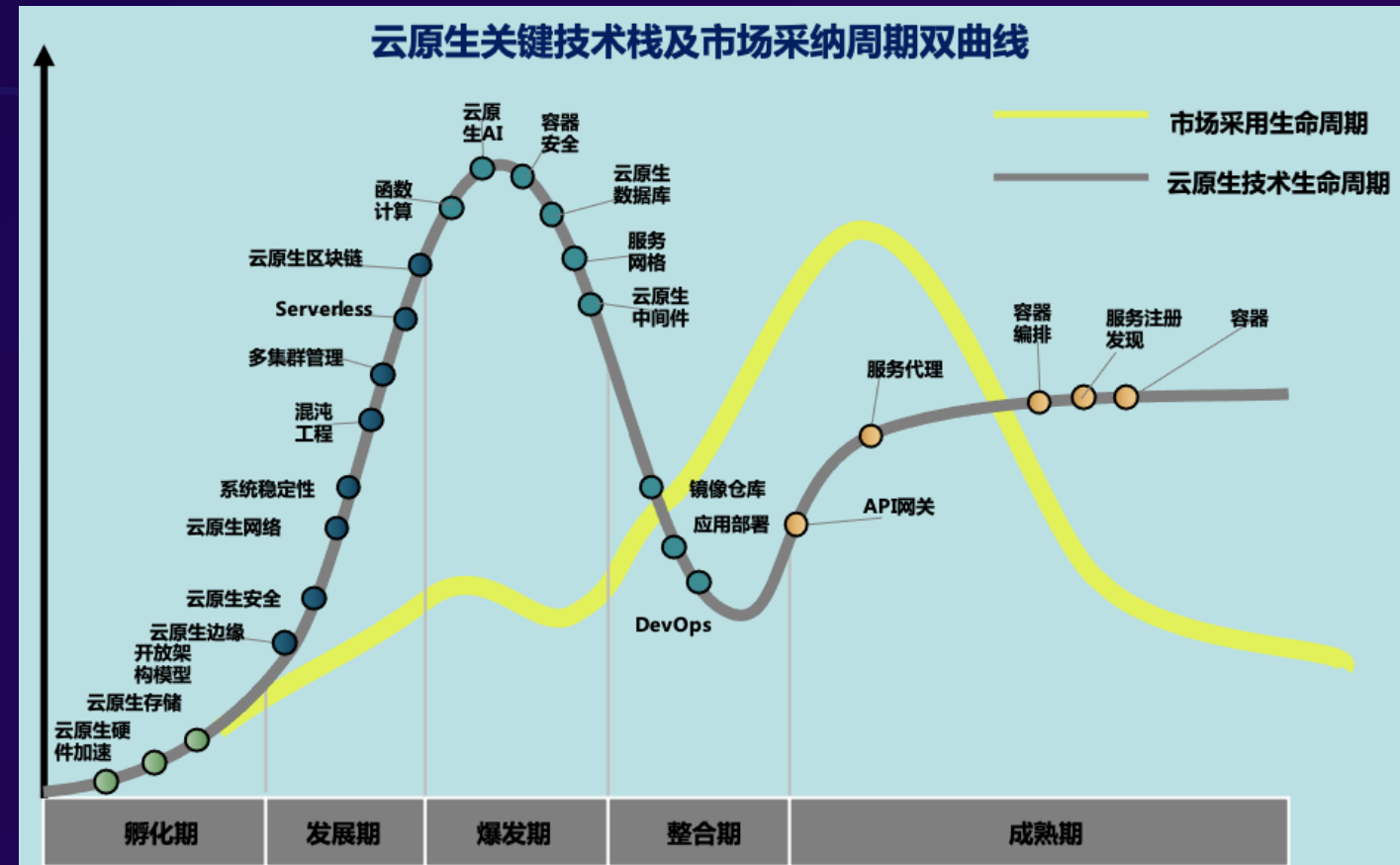
以云原生为技术“内核”，**向上支撑**行业数字化转型，助力企业**更快开发满足**业务需求



以云原生为技术“内核”，**向下打通**基础设施资源，更高效**调度**计算、存储、网络等资源。

云原生生态持续完善，向体系化应用演进

云原生**底层核心技术已完成整合趋于成熟**，细分领域的**衍生技术呈井喷式爆发**，据不完全统计技术生态的**热点开源项目已超300个**，涵盖技术能力的方方面面。同时云原生核心技术的稳固也为**跨领域的融合技术繁荣发展**夯实了基础，云原生化的大数据、AI、区块链等技术正在成为趋势，**以云原生为核心的融合应用时代即将到来。**



云原生价值已被广泛采纳，加速释放云计算应用效能

云原生技术带来的极致弹性能力、服务自治故障自愈能力以及大规模可复制能力，进一步加速了企业数字基础设施升级解放生产力，大幅提升了应用迭代速度赋能用户应用创新。

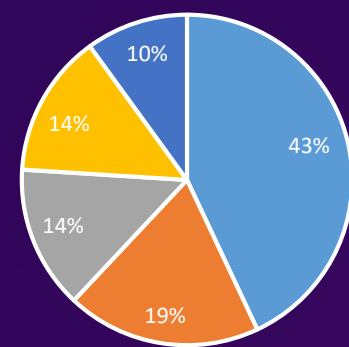
云原生技术的价值



云原生技术开始广泛进入生产环境

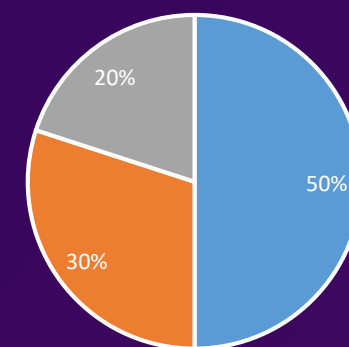
容器技术的采纳程度超过30%，**60%以上**的用户已在生产环境中应用容器技术；微服务架构已趋于主流，**80%**用户已经使用或计划使用微服务；Serverless技术崭露头角，**近30%**用户的生产环境中应用。

容器技术采用情况



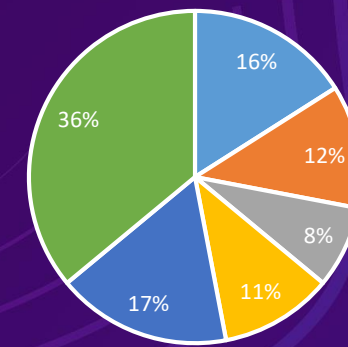
■ 已用于核心业务生产 ■ 已用于非核心业务生产 ■ 仅用于测试阶段
■ 评估考虑阶段 ■ 未采用容器技术

用户微服务架构采纳情况



■ 已经使用 ■ 计划使用 ■ 暂无使用

Serverless技术采用的情况



■ 已在核心业务应用 ■ 已在非核心业务应用 ■ 已在测试环境应用
■ 已在研究/学习环境应用 ■ 正在考虑使用 ■ 尚未使用

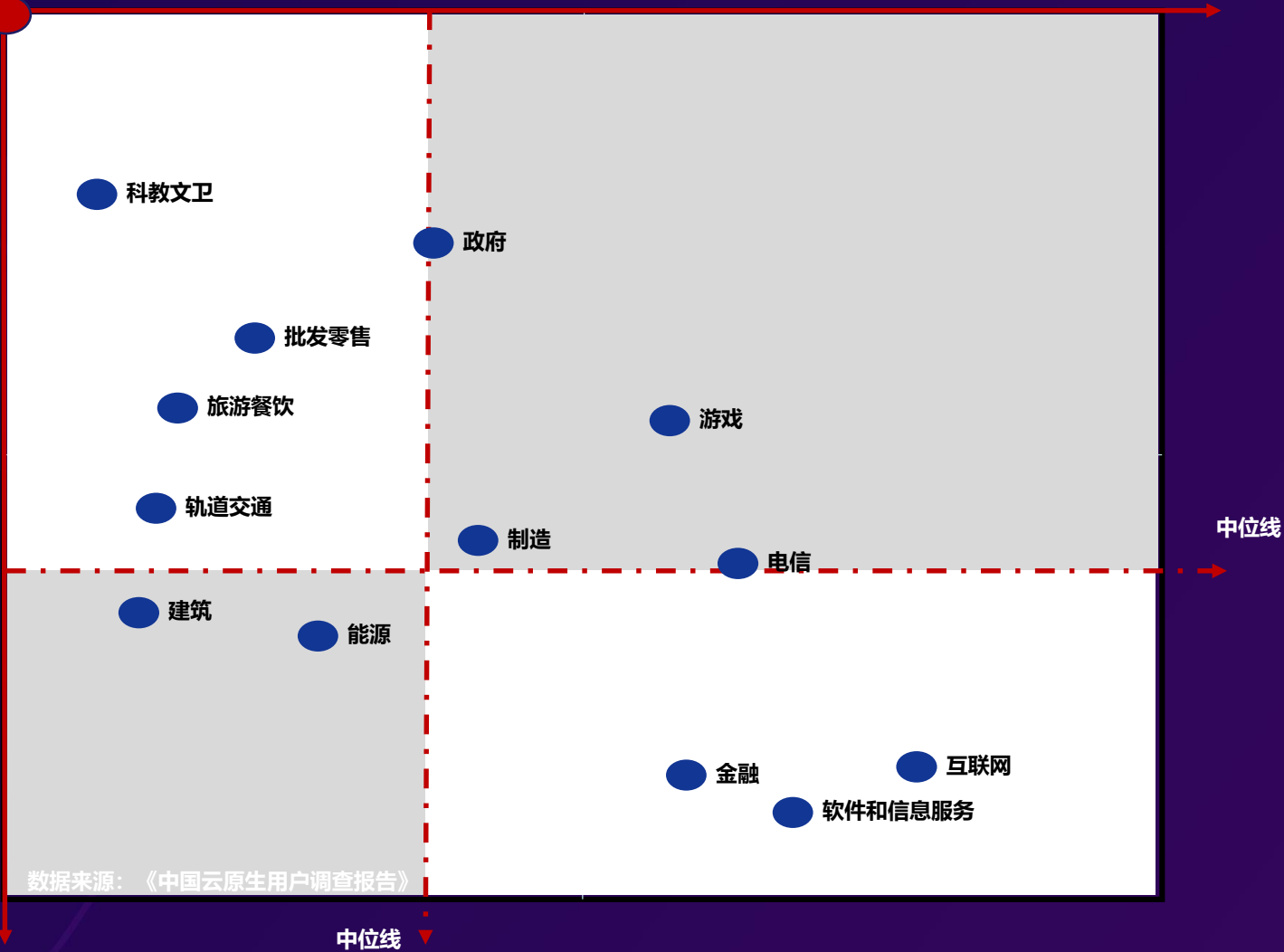
数据来源：中国信息通信研究院《云原生用户调查报告（2020年）》

用户采纳度攀升、资本涌入，云原生进入黄金发展期

在产业侧，以容器、微服务为代表的云原生技术在核心/次核心生产环境的采纳程度再迎新高，**全面云原生化已是共识**；细分领域**投融资市场活跃**，资本涌入催生新一批准独角兽，加剧市场繁荣。

云原生技术采纳程度

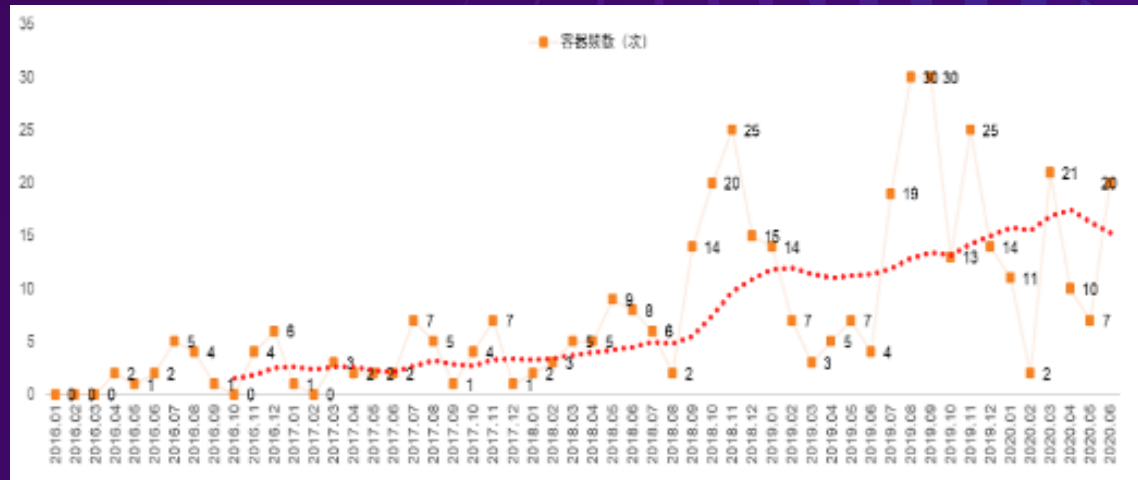
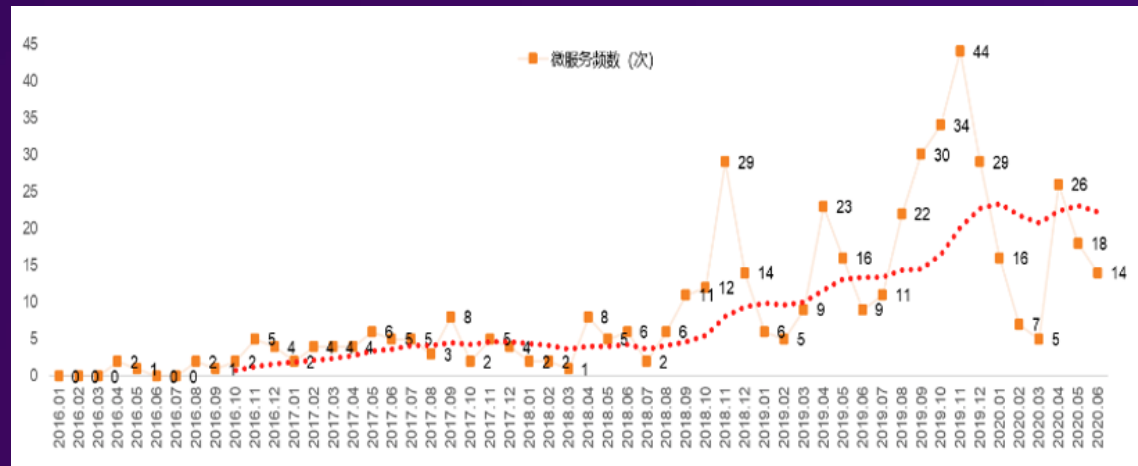
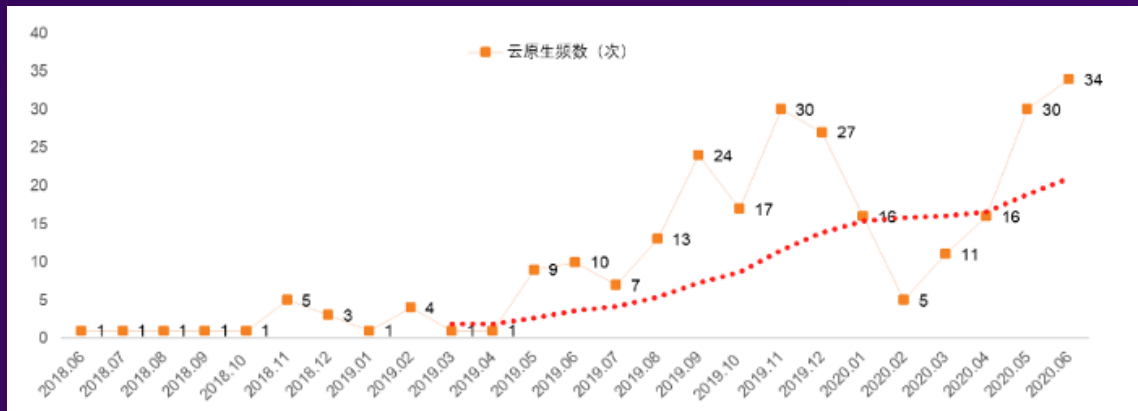
企业IT投入规模



2019-2020年云原生领域企业投融资情况（不完全统计）

序号	公司简称	融资轮次	融资金额
1	雅克云	天使轮	千万级RMB
2	睿云智合	首轮	千万级RMB
3	谐云科技	战略投资	千万级RMB
4	滴普科技	A+	5000万USD
5	时速云	B轮	千万级RMB
6	智领云	A轮	千万级RMB
7	博云	D轮	未披露
8	安畅网络	D1轮	亿元级RMB
9	小佑科技	天使轮	千万级RMB
10	StreamNative	Pre-A轮	百万级USD
11	才云科技	并购	
12	OpsMind	Pre-A	千万级RMB
13	科探信息	A轮	千万级RMB
14	飞致云	C+轮	未披露
15	精灵云	A+轮	千万级RMB
16	听云	C轮	亿元级RMB

2019-2020年招标文件中提及云原生的频率



数据来源：中国采招网、天风证券研究所

- 1 云计算进入全面云原生时代
- 2 云原生安全威胁全面显现
- 3 构建自底向上的云原生安全防护体系
- 4 云原生安全发展趋势
- 5 云原生安全成熟度标准体系

云原生安全挑战

云原生代表了一系列新技术，包括容器编排、微服务架构、不可变基础设施、声明式API、基础设施即代码、持续交付/持续集成、DevOps等，且各类技术间紧密关联。

- 技术挑战
云原生引入了大量基础设施新技术，导致安全工作者理解难度增加，云越来越像个黑盒，过去的安全工作多数只是围着核心业务外围转
- 组织挑战
安全建设和云基础设施关系紧密，导致安全职责需要重新考虑，安全组织和信息化其他组织的关系无法简单定义为谁主管、谁建设、谁负责

云原生架构安全



特征一：不可变基础设施

物理机

- 单个应用
- 物理服务器作为扩展单元
- 以年为单位的生命周期

虚拟主机

- 硬件虚拟化
- 虚拟机作为扩展单元
- 以月为单位的生命周期

容器

- OS 虚拟化
- 应用/服务为控制单位
- 以分钟级别的生命周期

Serverless

- 应用运行时虚拟化
- 资源作为扩展单位
- 以秒级别为生命周期

特征二：防护边界发生变化



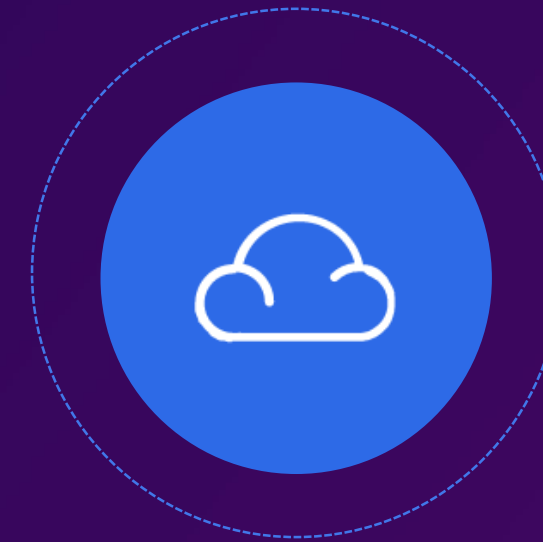
传统IDC

- 以物理位置或者设备为边界
- 主要以MAC/IP为标识



VM云计算

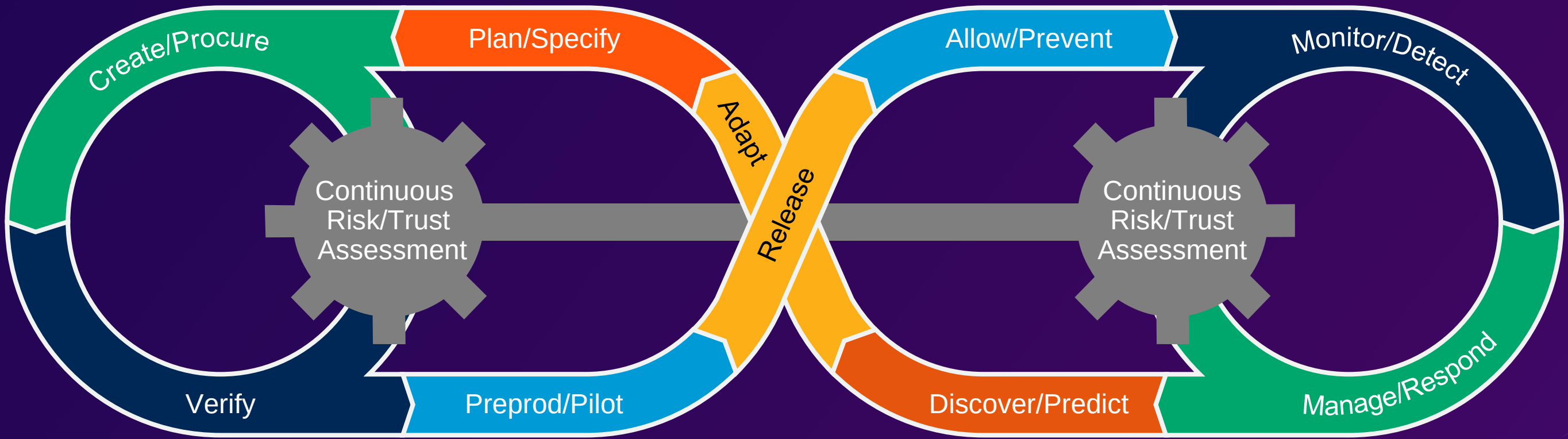
- 以虚拟机为边界
- 主要以IP为标识



云原生

- 以服务或应用为边界
- 主要以标签为标识

特征三：高度自动化的流程



云原生技术架构及应用模式变化，带来全新安全隐患



容器化部署成为云原生计算环境风险输入源

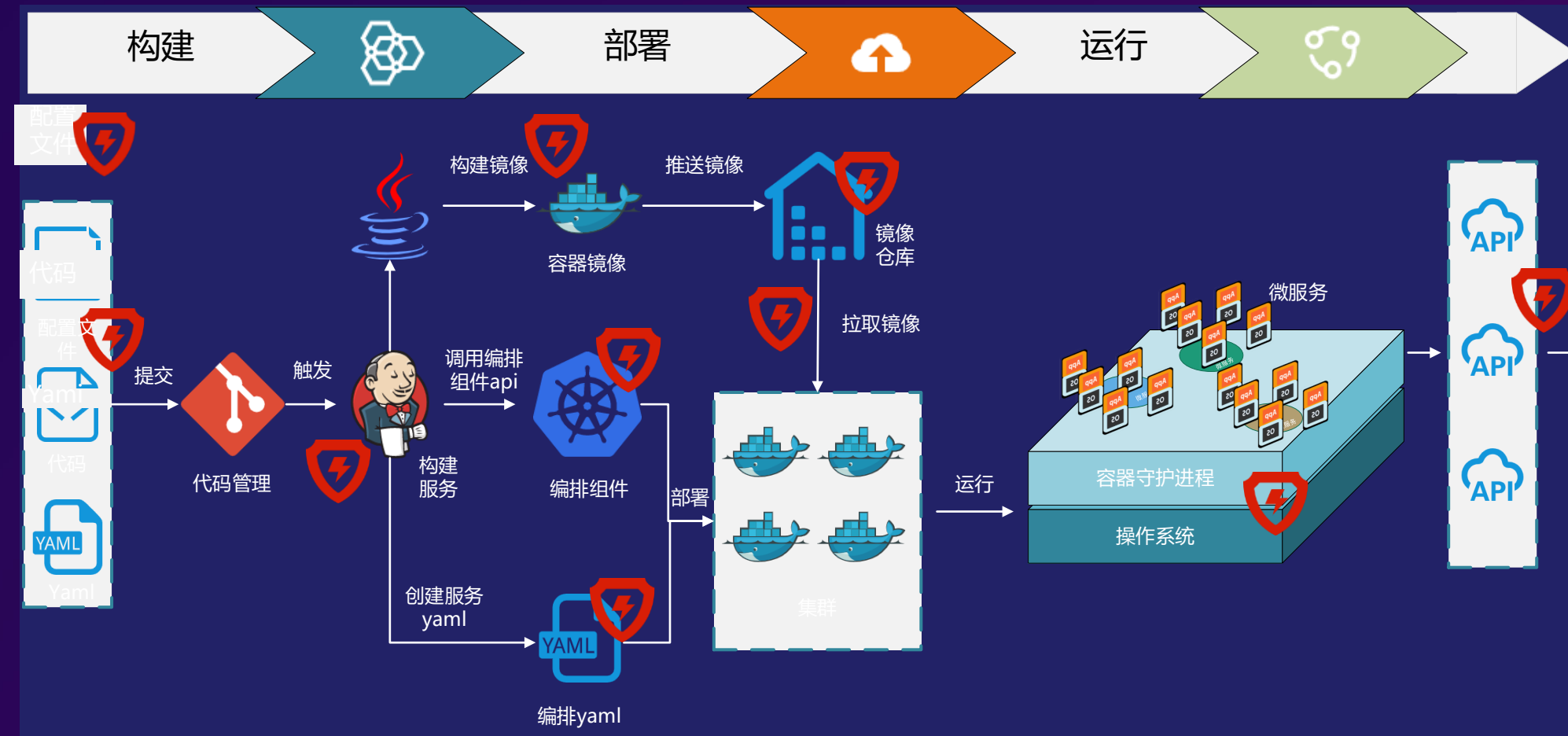
云原生网络安全风险：增加了东西向流量互访，避开了传统南北向网络防护，表现在：

- 访问控制粒度过粗；
- 网络分离管控不合理。

编排及组件安全风险：编排组件自身漏洞及管理缺陷，增加容器安全风险，表现在：

- 编排工具自身漏洞；
- 编排组件不安全配置；
- 不同安全级容器混合部署；
- 编排组件资源使用不设限；
- 编排节点访问控制策略配置不当。

容器构建、部署、运行的全链条存在漏洞引入和安全威胁扩散的风险。



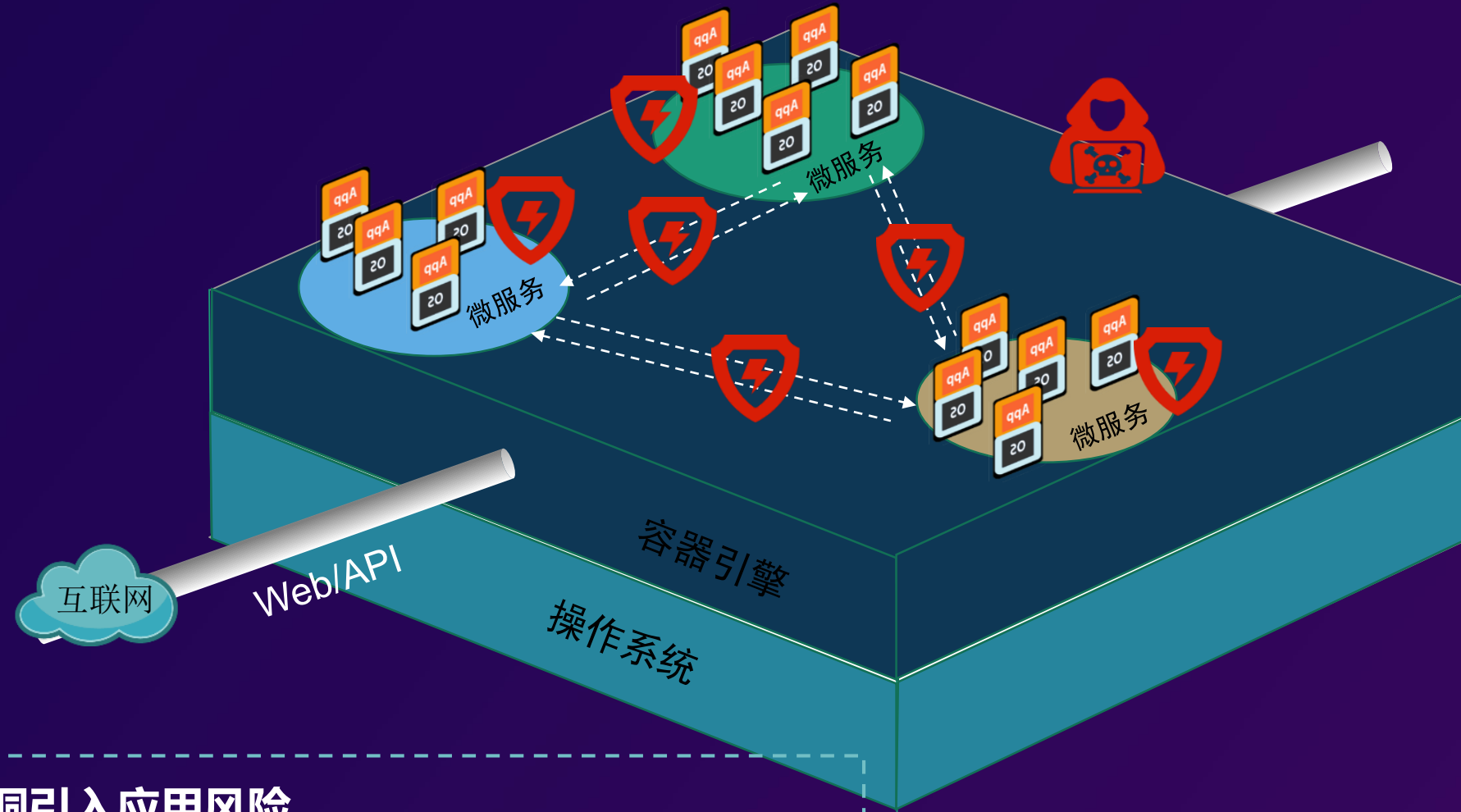
镜像及镜像仓库安全风险：镜像及镜像仓库模式，增加了软件供应链的监管风险，表现在：

- 镜像含软件漏洞；
- 镜像配置缺陷；
- 镜像来源不可信；
- 镜像仓库自身漏洞及管理问题；
- 镜像获取通道不安全。

容器运行时安全风险：共享操作系统内核，提升了逃逸风险概率及影响范围；容器生命周期缩短至分钟级，显著提升了应用管理难度，表现在：

- 容器危险配置导致逃逸攻击；
- 容器危险挂载导致逃逸攻击；
- 相关程序漏洞导致逃逸攻击；
- 宿主机内核漏洞导致逃逸攻击；
- 安全容器逃逸风险。

微服务细粒度切分增加云原生规模化应用风险



3

微服务治理框架漏洞引入应用风险

常用的微服务治理框架，例如Spring Cloud、Dubbo等都是基于社区的模式运作，引入了大量开源组件，虽然内置了许多安全机制，但默认值通常并不安全，常常引入不可预料的漏洞，例如，CVE-2019-3799、CVE-2020-5405。甚至有些漏洞长期缺乏修复，且修复复杂、成本较高。

1

微服务入口点增加导致攻击面增大

单体应用的场景下，入口点只有一个，所有的请求都从这个入口点进来，入口点设置防护就可以控制大多数风险。

微服务场景下，业务逻辑分散在很多进程里，每一个进程都有自己的入口点，暴露的端口数量急剧增加，导致防范的攻击面比原来大得多，风险也随之升高。

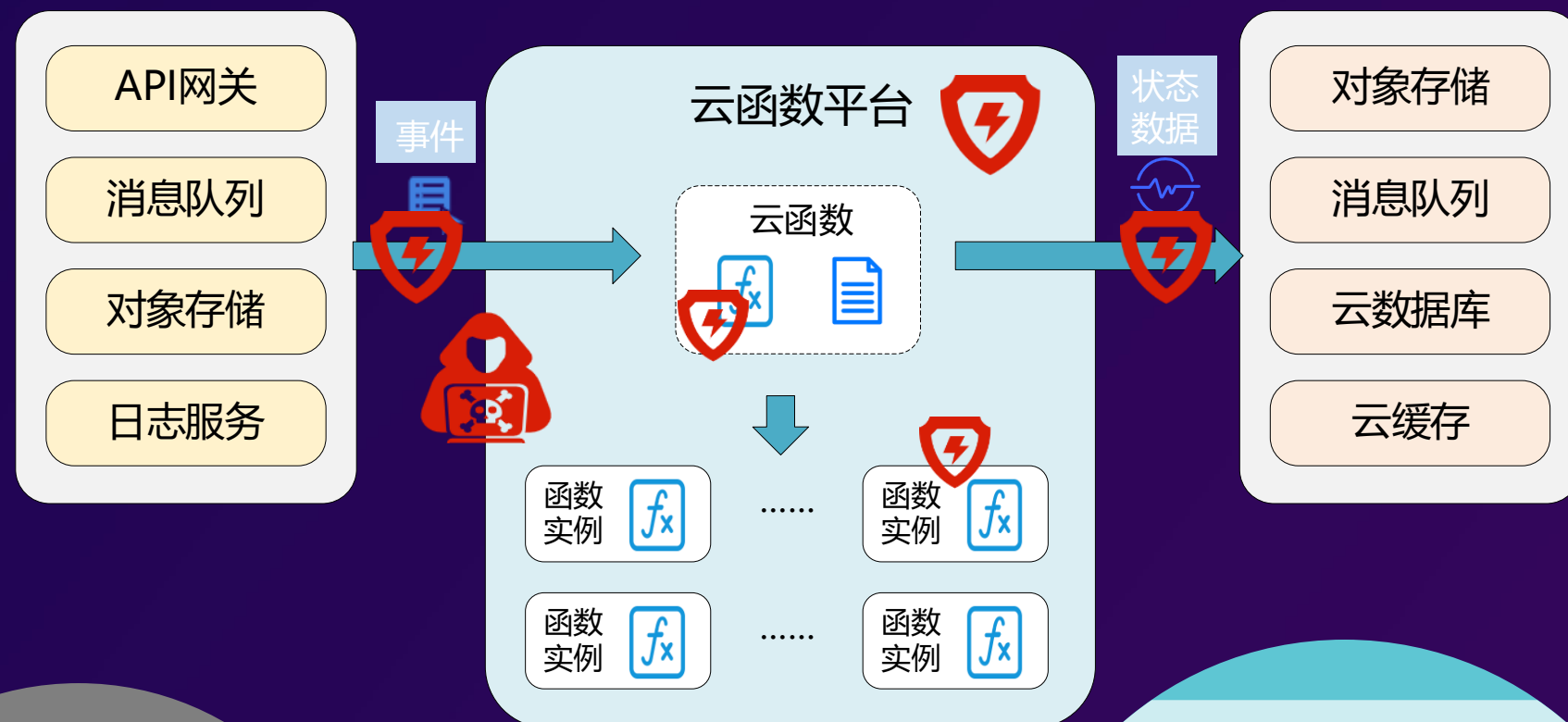
2

微服务调度复杂增加访问控制难度带来越权风险

单体应用的场景下，应用作为一个整体对用户进行授权，只需解决用户或外部服务与应用的认证授权。

微服务场景下，所有服务均需对各自的访问进行授权，明确当前用户的访问控制权限，人为因素导致认证授权配置错误成为了一大未知风险；且API数量激增，也增加了越权访问、注入攻击等风险。

Serverless灵活性带来模型和平台管控风险



Serverless模型包含了开发者开发、部署、运行的应用程序，以及云计算供应商提供的Serverless支撑平台。对应Serverless的安全风险包括：

- 一是应用程序本身固有的安全风险；
- 二是Serverless模型以及平台的安全风险。

程序固有风险

- ✓ 应用程序漏洞
- ✓ 第三方依赖库漏洞
- ✓ 消息明文传递等传统应用程序风险

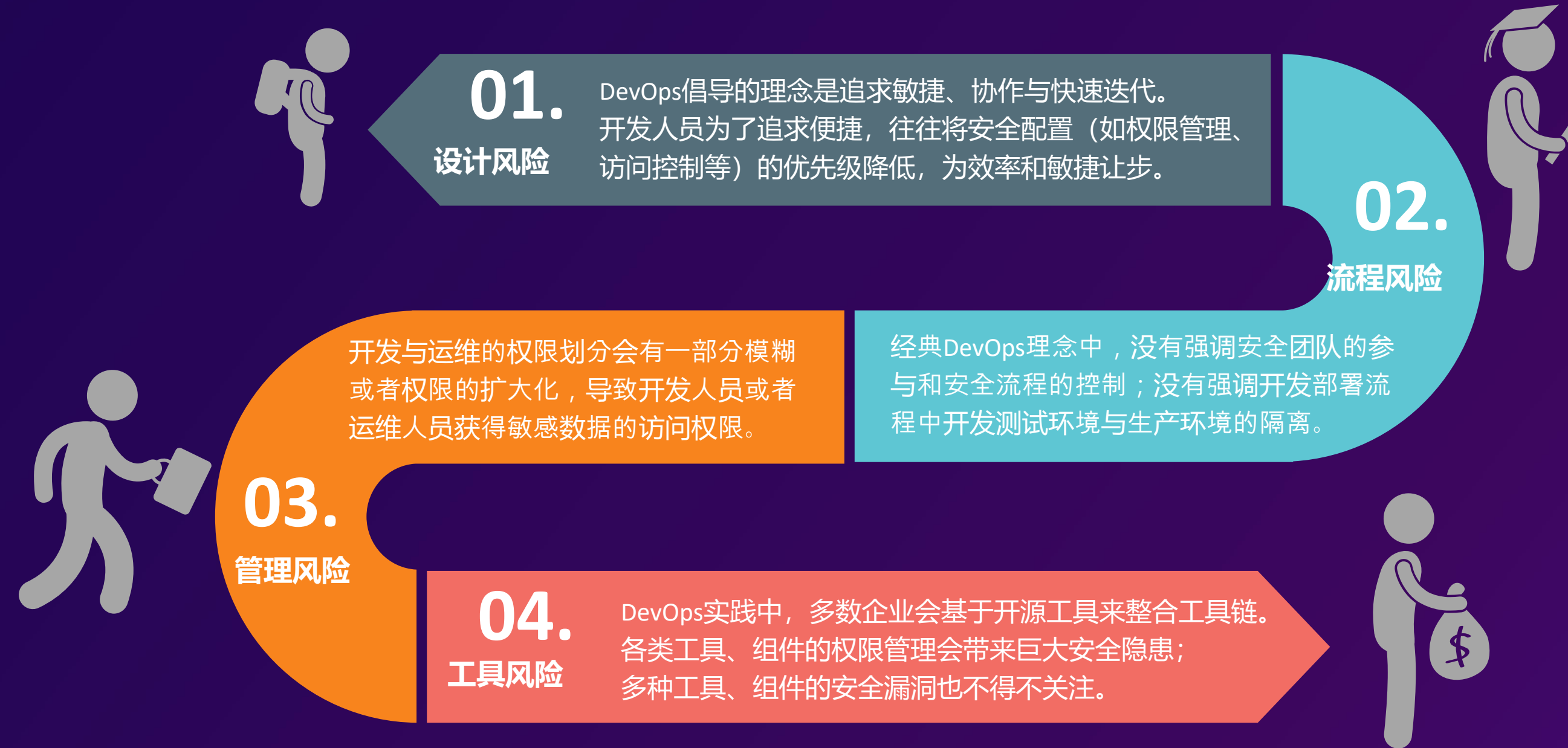
平台安全风险

- ✓ 平台自身漏洞
- ✓ 平台账户拒绝服务攻击（脏牛漏洞DoW）
- ✓ 平台强依赖性

计算模型风险

- ✓ 函数多源输入
- ✓ 资源权限管控不当
- ✓ 数据源增加导致数据泄露
- ✓ 环境变量替代配置文件存储
- ✓ 跨函数调用数据清理不及时

DevOps提升研运流程和安全管理的防范难度



API爆发式增长催化分离管控和权限滥用风险

云原生化之后，从基础架构层、到上面的微服务业务层都会有很多标准或非标准的API，**API的数量急剧增加、调用异常频繁。**

一方面，爆发式的增长导致API在身份认证、访问控制、通信加密、以及攻击防御等方面的**安全问题更加明显**，面临更多潜在的风险。

另一方面，企业面对大量的API设计需求，其相应的**API安全方案往往不够成熟**，从而引起滥用的风险。

DDoS攻击风险

资源和速率未受到限制或者限制不足引入拒绝服务攻击。

数据泄露风险

安全限制措施不足，导致不同安全级用户隔离不足，以及API权限混乱带来数据泄露风险。

未授权访问

API管理不当或者API设计存在缺陷引入未受限访问攻击。

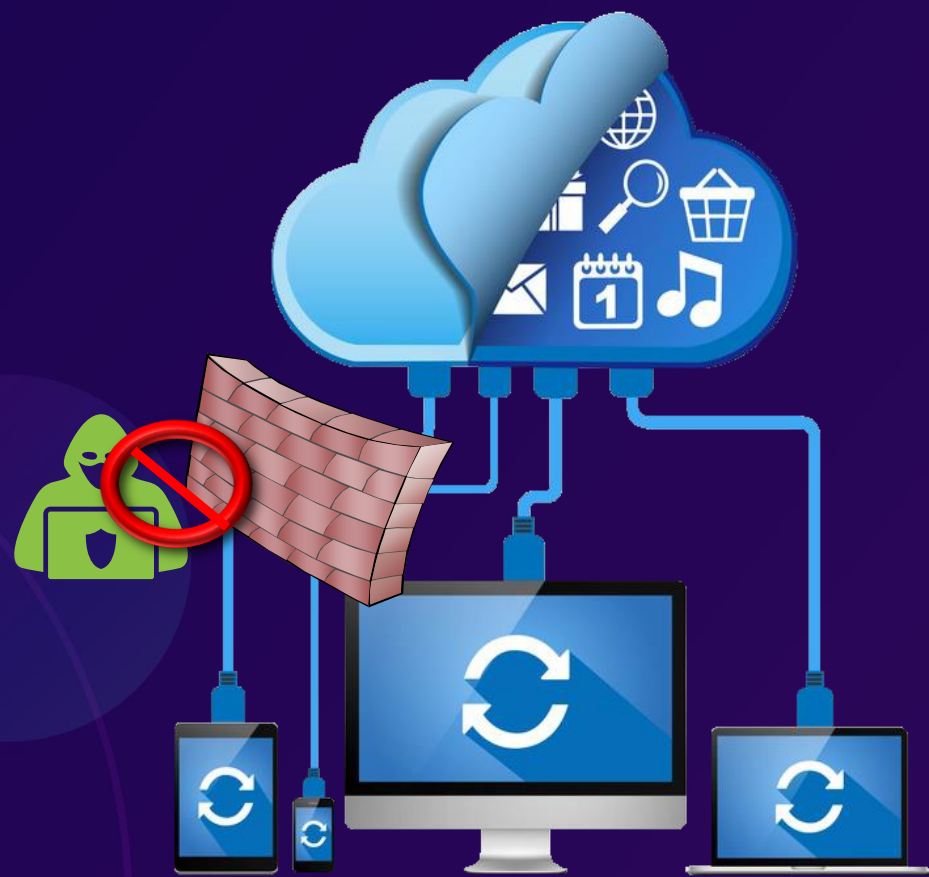


全新的威胁带来了全新的攻击手段

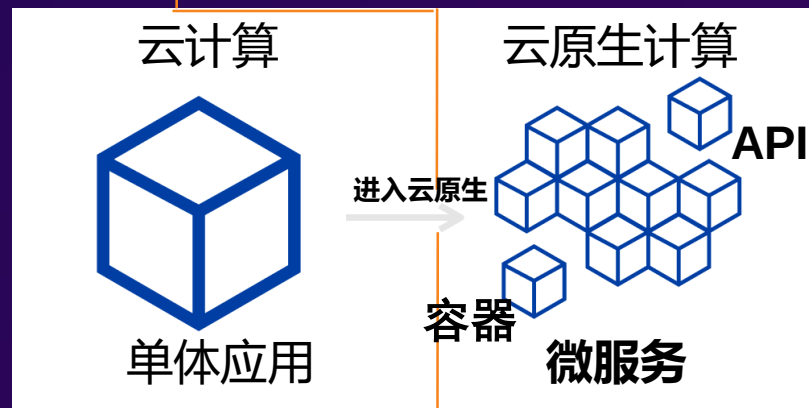
初始访问(3)	执行(4)	持久化(4)	权限提升(4)	防御绕过(6)	凭证访问(2)	发现(2)	影响(3)
攻击对外开放的服务	容器管理命令	外部远程服务	逃逸到宿主机	在宿主机构建镜像	暴力破解	容器和资源发现	端点拒绝服务
外部远程服务	部署容器	植入内部镜像	滥用提权	部署容器	密码猜测	网络服务发现	网络拒绝服务
可用账户	预定任务/作业	预定任务/作业	预定任务/作业	损害防御	密码喷洒		资源劫持
缺省账户	容器编排作业	容器编排作业	容器编排作业	禁用或修改工具	凭证填充		
本地账户	用户执行	可用账户	可用账户	宿主机指示器移除	不安全的凭证		
	恶意镜像	缺省账户	缺省账户	伪装	文件中的凭据		
		本地账户	本地账户	匹配合法名称或位置	容器API		
				可用账户			
				缺省账户			
				本地账户			

*针对容器的ATT&CK攻击模型

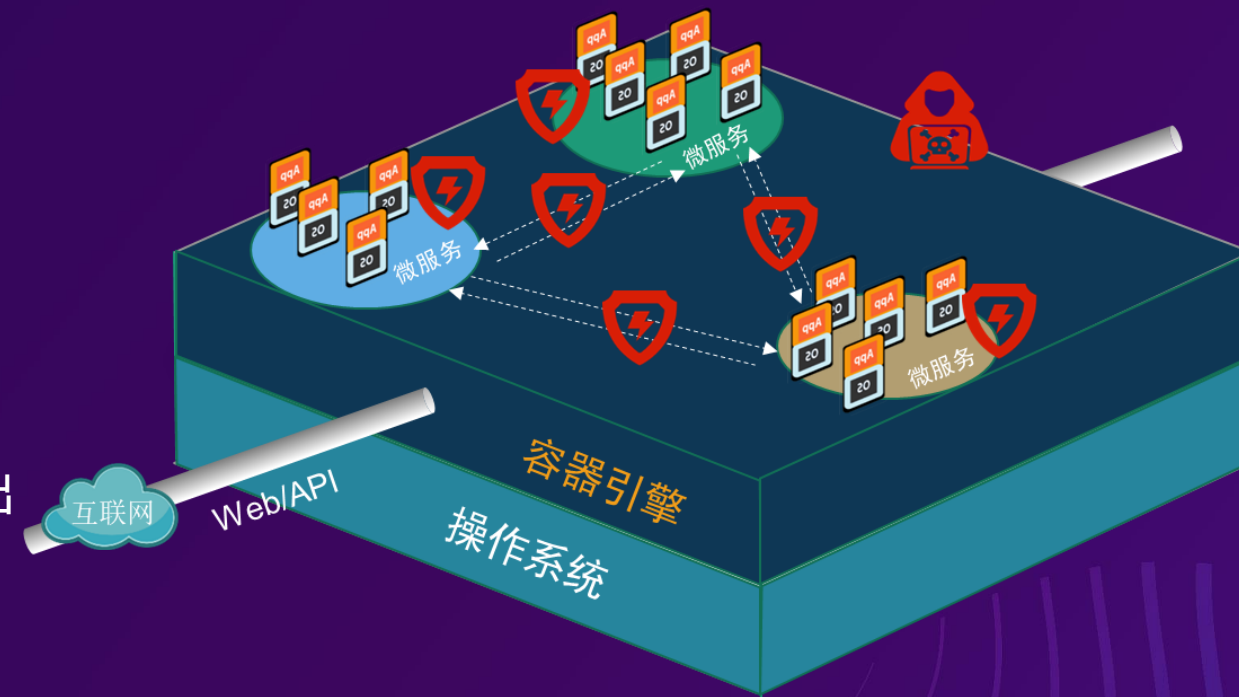
传统基于边界的安全防护模型不能满足云原生架构下的安全需求



基于边界的安全防护



1. 声明式API → 规模应用为应用防护提出更高要求
2. 微服务 → 应用周期变短、动态性变强，增加监控和溯源难度
3. 研发运营一体化 → 要求关注软件流转的全链条安全
4. 容器及容器编排 → 容器生命周期缩短及多容器共享操作系统，增加逃逸风险
5. 不可变基础设施 → 解耦

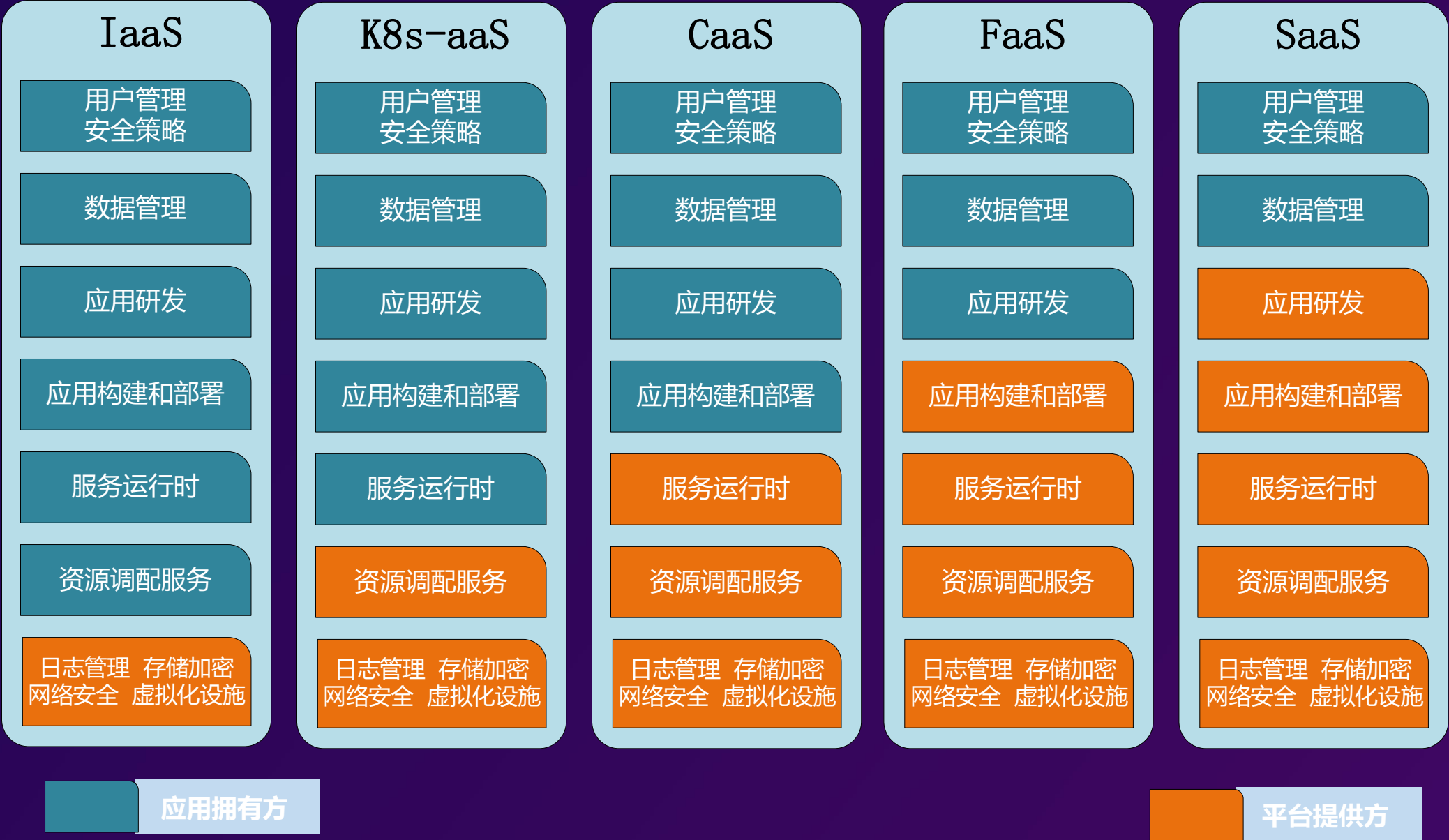


基于细粒度和动态工作负载的安全防护

- 1 云计算进入全面云原生时代
- 2 云原生安全威胁全面显现
- 3 构建自底向上的云原生安全防护体系
- 4 云原生安全发展趋势
- 5 云原生安全成熟度标准体系

云原生安全防护范围及责任划分

云原生安全所保护的**对象**，是指以**容器**技术为基础底座，以**DevOps**、**面向服务**等云原生理念进行开发，并以**微服务**等云原生架构构建的业务系统所共同组成的信息系统。



容器服务、Service Mesh与Serverless等均属于云原生范畴。

不同服务模式，具有不同的责任模型，各自关注不同的防护重点。

云原生安全遵循的设计原则



零信任

假设环境中随时存在攻击者，不能存在任何的隐形信任。

通过细粒度拆分构建微边界的架构模型，并通过执行策略限制消除数据、资产、应用程序和服务的隐式信任。



安全左移

在云原生安全建设初期将安全投资更多地放到开发安全，包括安全编码、供应链（软件库、开源软件）安全、镜像及镜像仓库安全等。



持续监控和响应

转被动为主动，持续监控尽可能多的云原生环境，如网络活动层、端点层、系统交互层等；

同时应建立持续响应的防护机制，对攻击进行迅速分析和处理，并建立数据收集池进行溯源追踪，发现系统中的安全缺陷。

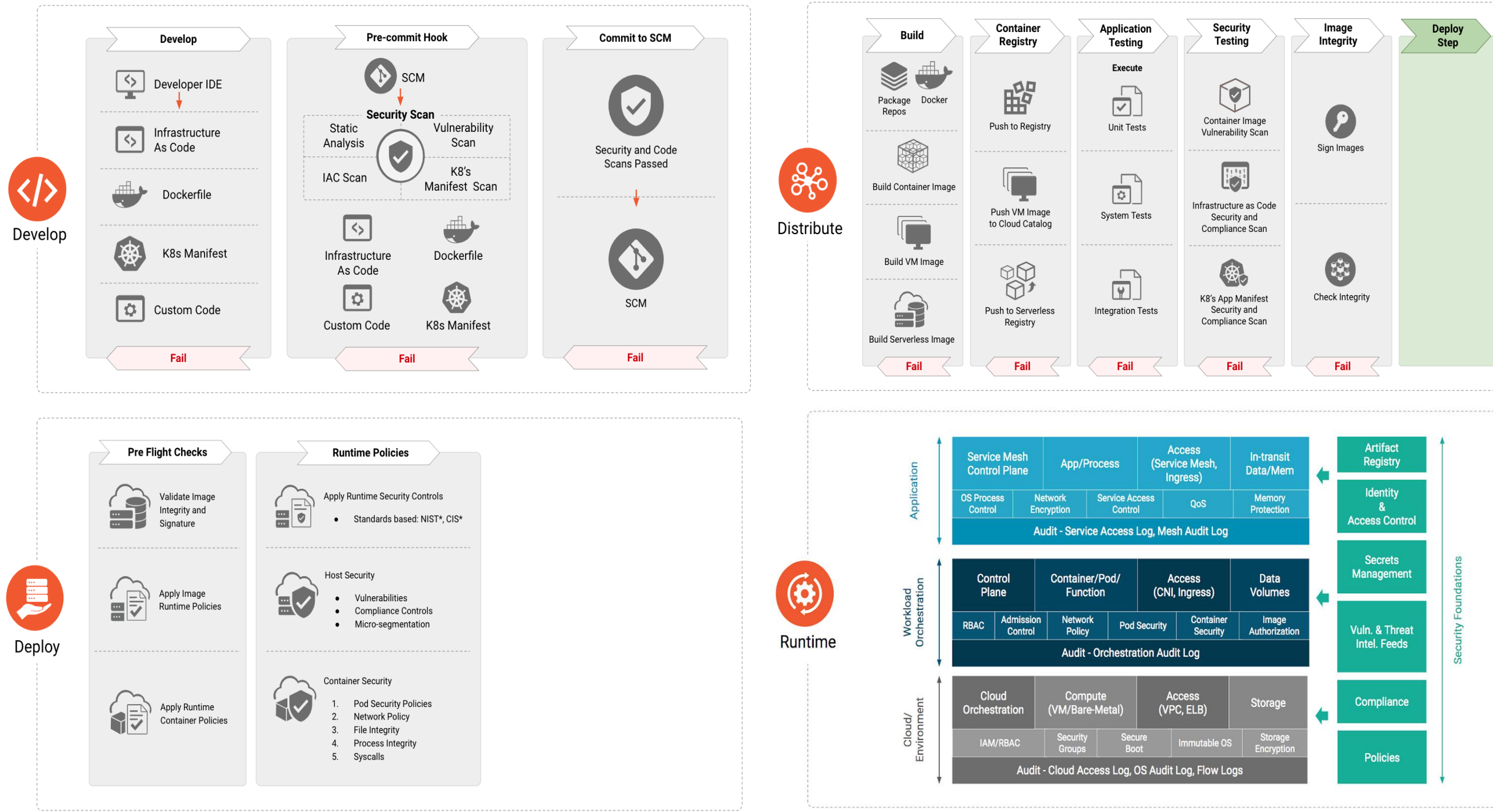


工作负载可观测

运用可视化工具发现和记录容器快速变化的应用行为，清晰地观察微服务和中间件调用关系。

为自动化的安全检测提供详细准确的运行状态数据，为自动化的云原生安全提供充足的决策依据。

应用生命周期视角下的云原生安全体系



云原生安全防护体系



传统安全
防护边界为物理机
主要以MAC/IP为标识



云安全
防护边界为虚拟机
主要以IP为标识



云原生安全
防护边界为服务或应用
主要以标签为标识



01.基础设施安全



计算安全

- **主机访问控制**
主机账号闭环安全管理
具备双因素/多因素安全认证能力
具备操作审查能力
- **系统基础安全加固与配置**
操作系统镜像的统一化、标准化
基线检测（基础服务、核心安全能力）
- **主机入侵检测**
基于主机层日志、文件、进程、流量等信息来实现多维度互补的入侵检测



存储安全

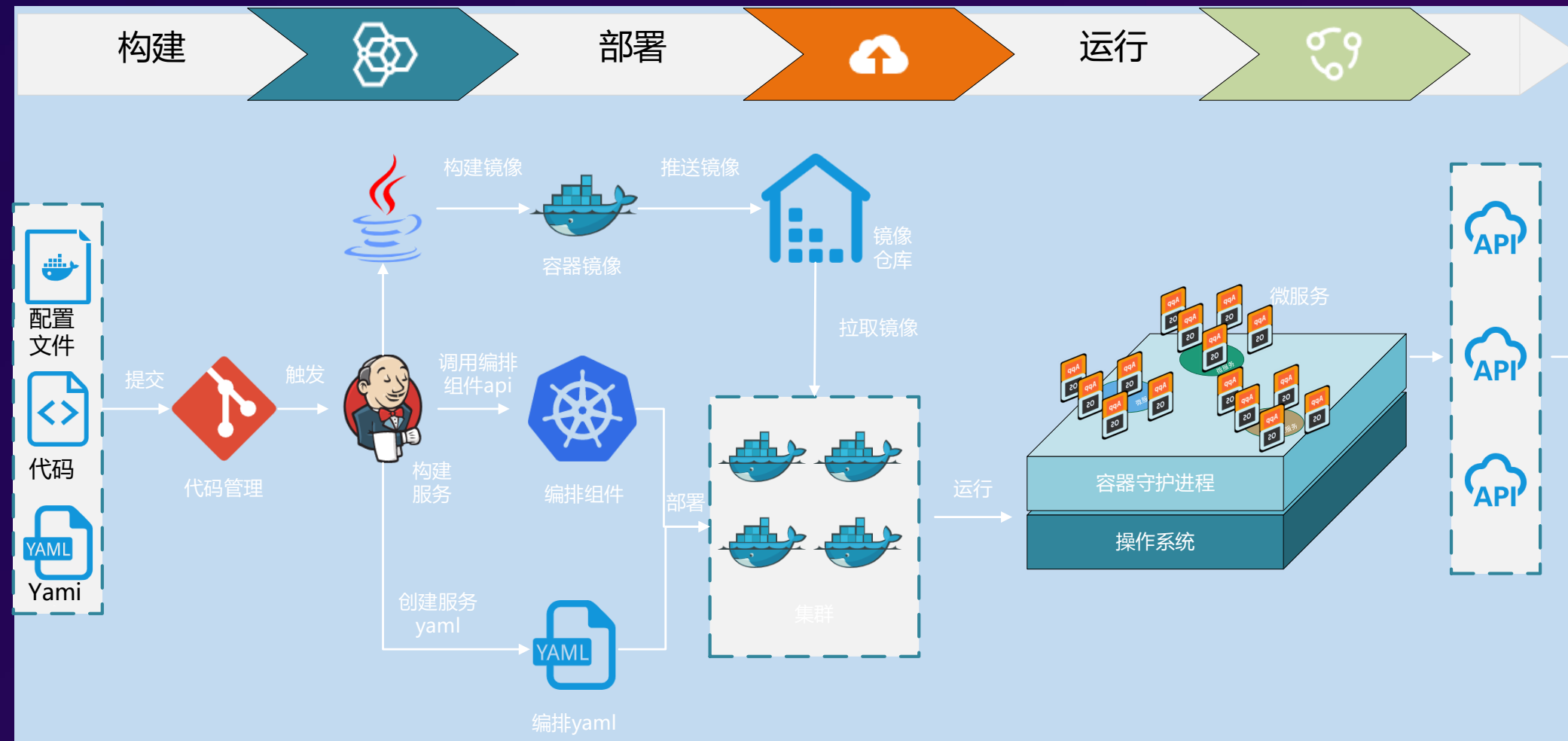
- **网络设备安全**
设备管理有独立隔离的网络环境
设备访问有明确的授权流程/机制
资产信息/策略配置通过统一平台维护
- **网络访问控制**
物理网络与云主机网络边界
这些网络与公网边界
动态、最小化、可追溯的访问控制
- **网络攻击检测与防御**
DDoS防御
应用层防攻击能力



网络安全

- **认证与访问控制**
访问入口的安全认证
访问空间和访问目录的权限控制
读写操作得记录和审计
- **备份管理与数据恢复**
多集群、多数据中心复制存储
设置备份程序、频率、保存周期
- **数据传输与存储加密**
传输加密、存储加密
密钥管理

02.云原生计算环境安全



1 云原生网络安全防护

- 基于**服务粒度**、**基于Pod**的流量和入侵行为检测
- 实现细粒度访问控制策略
- 针对**东西向流量**设计**基于命名空间、容器间、容器与节点间的微隔离方案**

2 编排及组件安全防护

- 基线扫描
- 漏洞检测
- 敏感信息加密
- **基于不同角色的细粒度访问控制策略**，且具备可扩展性和动态性
- 资源隔离与限制

4

运行时安全防护

- **异常行为监控**
 - ✓ 不安全启动监控
 - ✓ 文件完整性监控
 - ✓ 恶意行为监控 (恶意访问、恶意文件、恶意程序)
 - ✓ 攻击和无文件攻击行为监控
 - ✓ 网络连接和反向连接行为监控
 - ✓ 容器运行行为基准检查

● 入侵行为响应

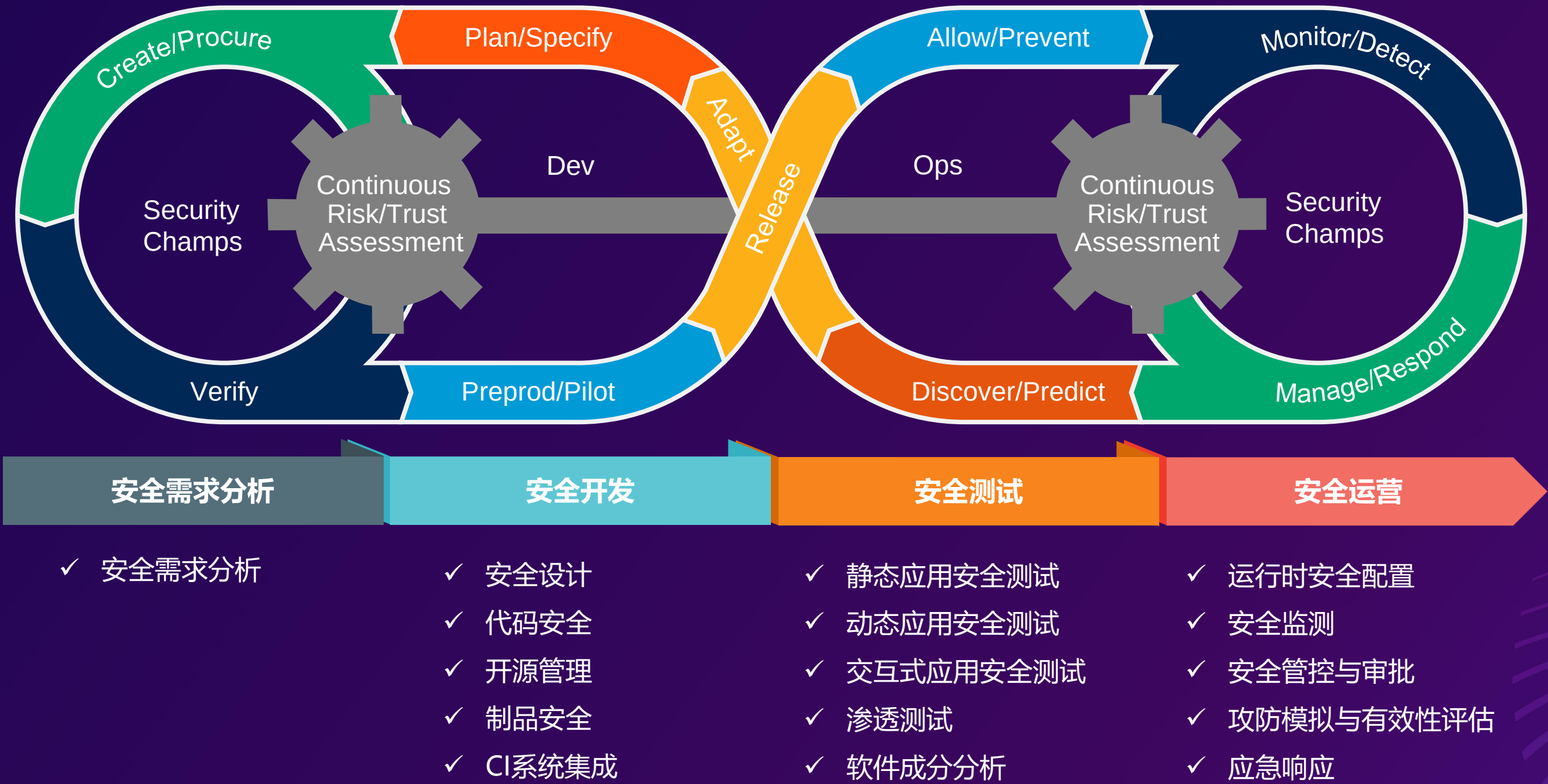
- ✓ 启动时入侵行为阻断
- ✓ 实时入侵行为响应

3

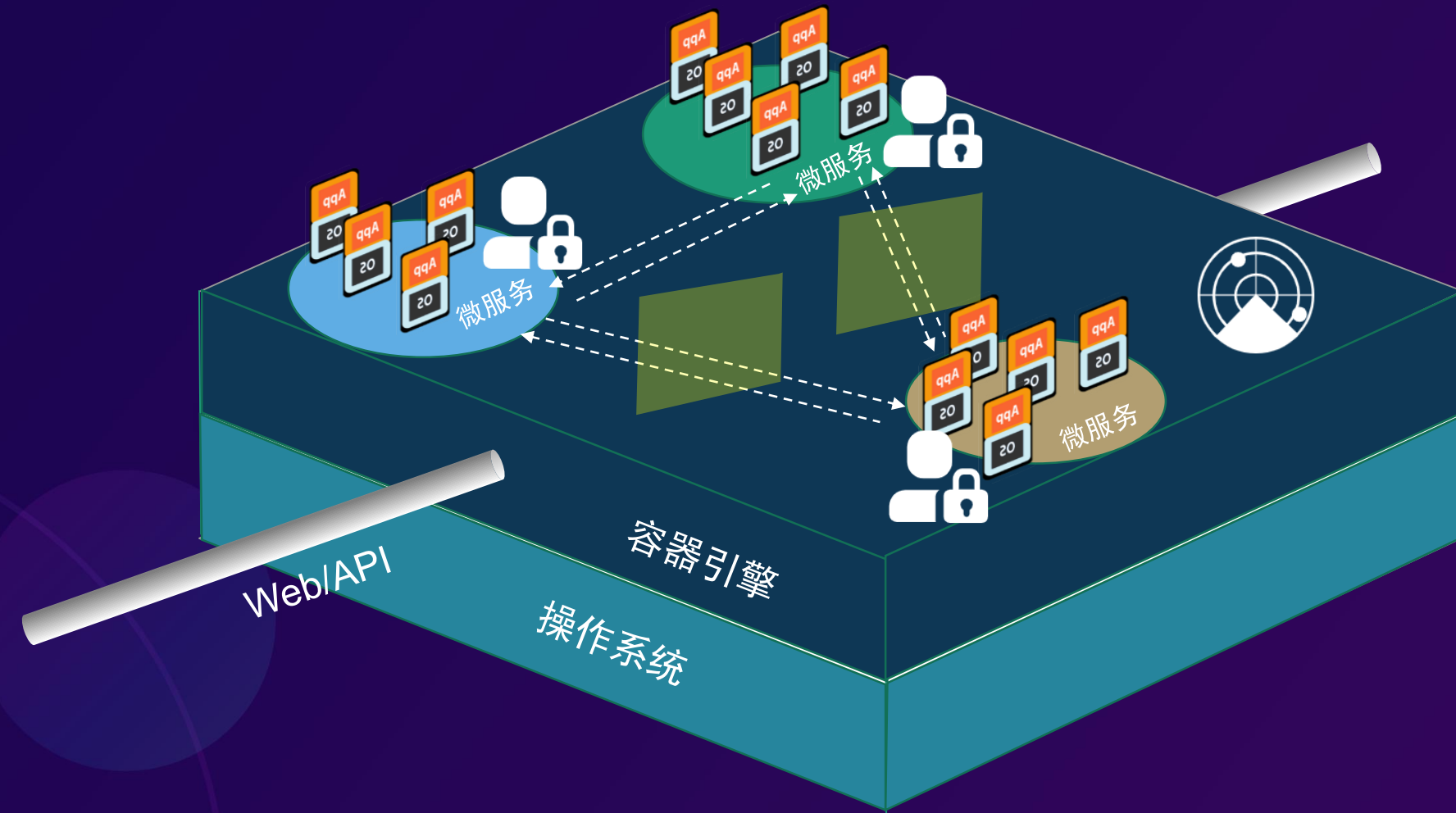
镜像及镜像仓库安全防护

- 镜像完整性保护 (**镜像签名技术**等)
- 镜像扫描
 - ✓ 安全基线检测
 - ✓ 漏洞检测
 - ✓ 恶意镜像检测
- 在集群节点上启用**镜像阻断**并防止被绕过
- 镜像**仓库访问控制**
- 镜像**仓库安全通信**

03.云原生研发运营安全



04.云原生应用安全——微服务



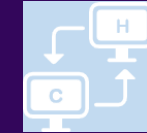
微服务安全的建设:

- 一是需要与DevOps进行集成, **针对微服务的漏洞进行发现**;
- 二是需要关注由于微服务的拆分, 带来的**更频繁的东西向访问流量**;
- 三是需要做好**微服务之间的访问控制和通信安全**, 提高应用的健壮性, 以避免不安全的、未授权的恶意访问。



访问控制

- ✓ 建立集中的架构管理所有微服务的访问策略;
- ✓ 提供细粒度的内部服务间认证与外部服务认证;
- ✓ 具备网关对服务请求的控制能力;
- ✓ 具备应用端对服务访问的控制能力。



安全通信

- ✓ 提供用户与服务 (南北向) 安全通信能力;
- ✓ 提供服务与服务 (南北向) 安全通信能力;
- ✓ 安全服务策略具备单个微服务节点的处理能力;
- ✓ 使用SSL/TLS建立安全的连接。



漏洞扫描

- ✓ 针对运行中的代码、服务、接口进行动态扫描;
- ✓ 基于多个漏洞库进行漏洞扫描;
- ✓ 支持微服务的自动发现、自动管理;
- ✓ 必要时支持业务逻辑的手动发现能力。

04.云原生应用安全——Serverless

对应Serverless安全威胁，Serverless的安全防护也可以从两个层面展开：一方面是针对Serverless应用程序本身的安全防护（传统方法）；另一方面是**针对Serverless计算模型以及平台的安全防护（重点/难点）**。



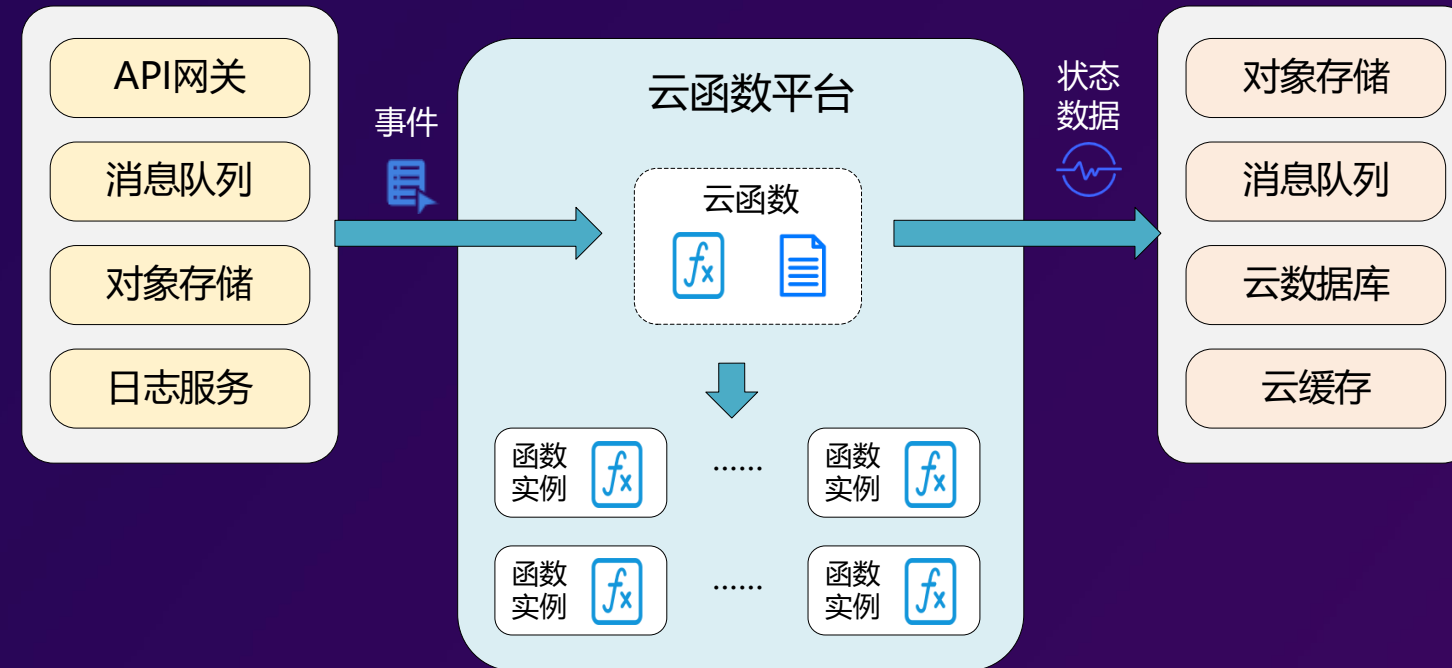
访问控制

- ✓ 赋予函数不同的角色，实现函数层面访问控制；
- ✓ 运用最小权限原则，每个用户只能访问指定资源；
- ✓ 每个函数应将任何事件输入视为不受信任的源，并进行安全校验。



平台账号安全防护

- ✓ 提供账单告警机制对用户进行账号消费告警（应对DoW攻击）；
- ✓ 参考方法：设定调用频率与调用费用阈值；
- ✓ 参考方法：基于资源限额进行控制。



Serverless资产业务梳理

- ✓ 应用的设计阶段对资产业务进行详细梳理；
- ✓ 确认函数间的逻辑关系，函数调用关系发生变化后进行安全审计；
- ✓ 确认应用的数据类型及数据的敏感性；
- ✓ 评估可访问数据API的安全性等。



FaaS平台函数隔离

- ✓ 基于FaaS平台，提供基于不同租户、不同应用的函数隔离机制；
- ✓ 参考方法：基于弹性计算云模型实现函数隔离；
- ✓ 参考方法：基于安全容器模型实现函数隔离。

05.云原生数据安全

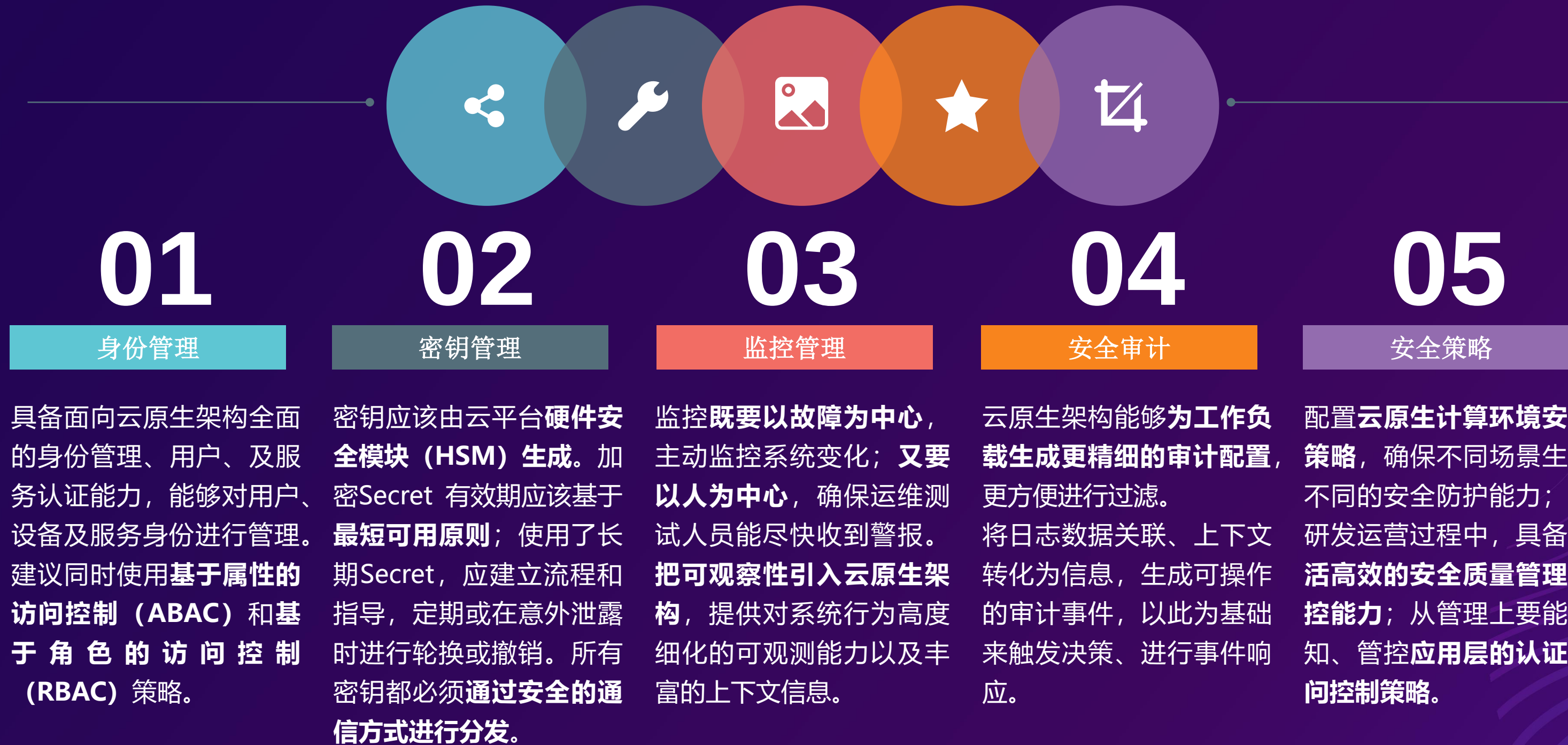
云计算向云原生架构演进升级的过程中，数据安全面临的威胁以及防护思路**本质上没有明显的变化**。但是，随着云原生对业务迭代及运维效率的提升，势必也对数据安全防护的**实施成本与运营效率**有了进一步提升的要求。



为确保数据安全防护方案与业务层更加解耦、方案应用操作上对上层业务更加透明，需要：

- ✓ 实现容器安全登录鉴权与租户企业组织信息映射；
- ✓ 密码/凭据安全托管能力built-in到对应云产品/DevOps基础设施上；
- ✓ 基于sidecar模式做细粒度网络访问控制、API调用异常监测等。

06.安全管理



云原生安全建设的规划



容器/集群

- 镜像安全
- 容器运行时安全
- 集群安全
- 网络层访问控制

微服务

- 应用安全
- 微服务API安全
- 服务网格化安全
- 应用层访问控制

无服务

- RASP

安全运营

- 事件检测
- 事件响应
- 事件处理

云原生安全建设需要注意的几个关键点

01

云原生安全策略先行，结合实际，建立基线及准入机制

02

全面的考虑云原生安全整体架构

03

根据云原生的建设节奏，逐步完善

04

贴合云原生技术演进方向，防止建设完不能用或者没有用

05

贴合云原生的特点，使用符合云原生特点的解决方案

- 1 云计算进入全面云原生时代
- 2 云原生安全威胁全面显现
- 3 构建自底向上的云原生安全防护体系
- 4 云原生安全发展趋势
- 5 云原生安全成熟度标准体系

云原生安全开启多元主导、深度融合、轻量设计趋势

安全技术的主导力量从单边走向多元

云服务商与安全厂商势必将加强深度合作，结合双方在技术研究、人才储备、产品应用等方面的积累和经验；
在云原生安全不同赛道将衍生出更加专注于细分领域的安全服务商，进一步丰富和完善云原生安全生态。

安全产品形态从粗暴上云转向与平台/应用深度融合

云原生安全将与云原生平台、应用深度融合，提供新型云原生信息基础设施的防护、检测和响应能力；
并将云原生技术赋能于这些安全产品、应用和解决方案，实现进程级防护能力、微隔离访问控制、全流程实时监控响应，实现安全方案的内生配置和深度融合。

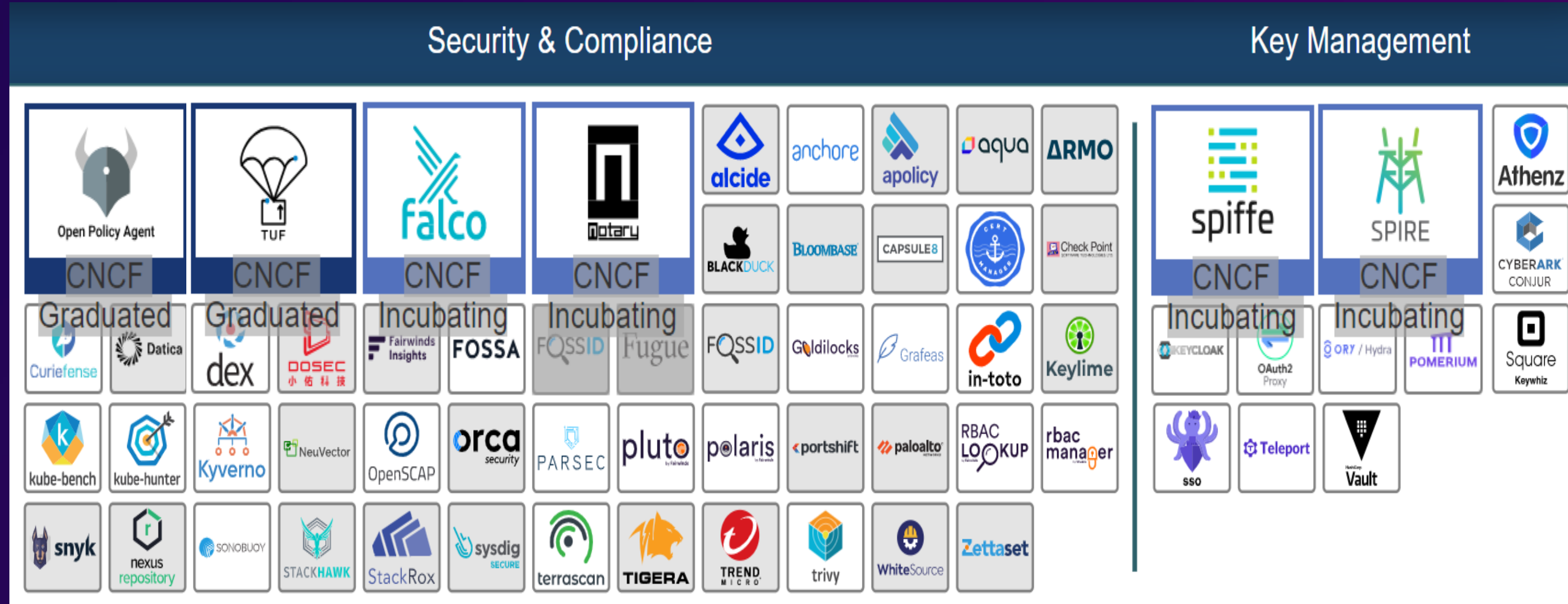
安全设计理念从以人为中心转向以服务为中心

传统安全侧重以人为主的防护策略，已经不能满足云原生实例频繁启停的生命周期变化以及海量的东西向流量交互；
以服务为中心构建的容器安全防护措施、持续监控响应模型和可视化平台，将成为云原生安全防护的主流方案。

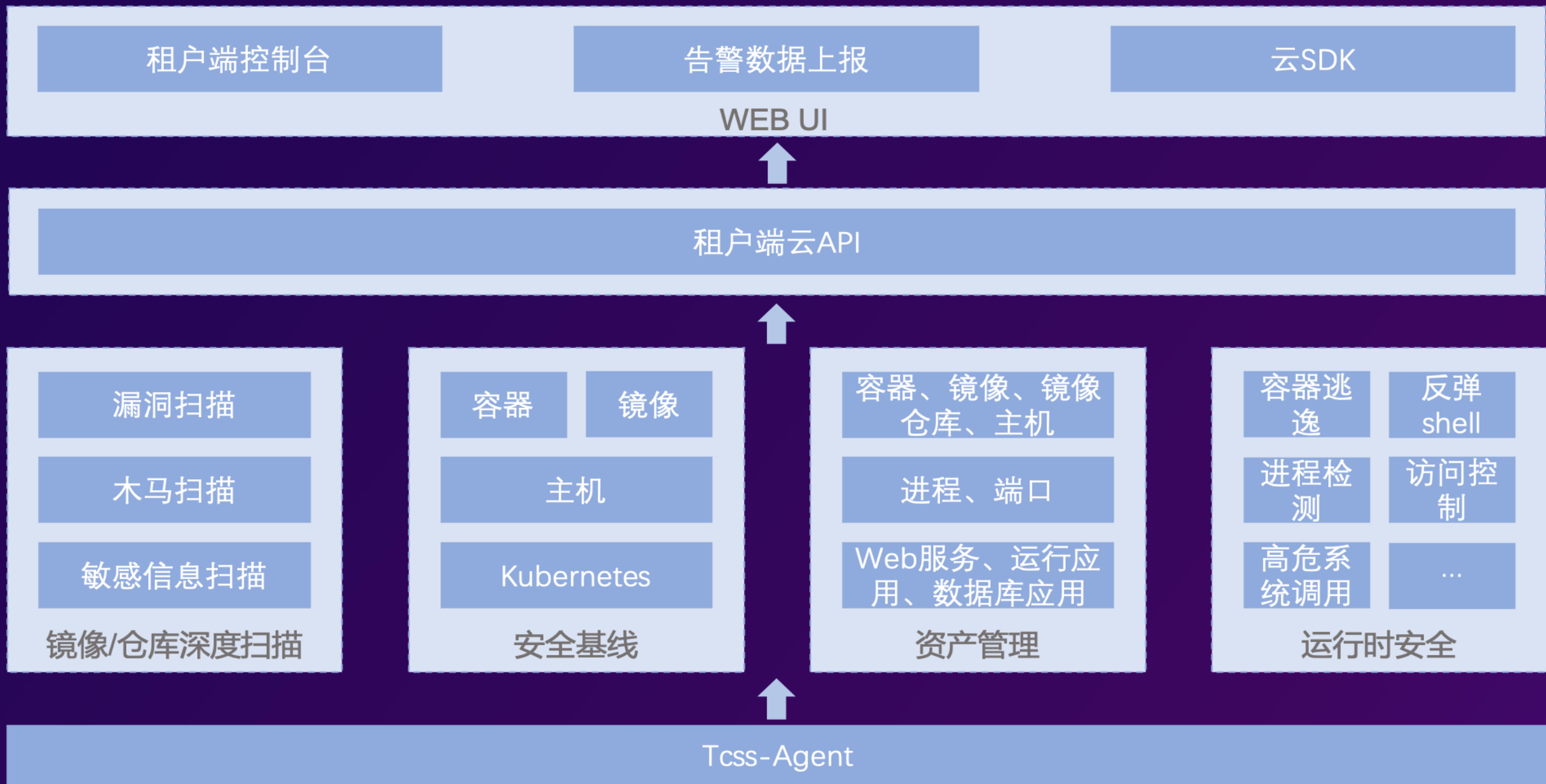
安全落地方案走向轻量化、敏捷化、精细化

随着容器部署的环境也越来越复杂、运行实例生命周期越来越短，要求安全方案的反应必须迅速敏捷，及时发现容器启动，密切跟踪容器行为，并在发现异常时迅速反映；
云原生提供的服务粒度越来越细，相应的安全方案的防护粒度也需越来越细，从过去的容器粒度，到目前的函数粒度，未来可能是语句粒度、变量粒度。

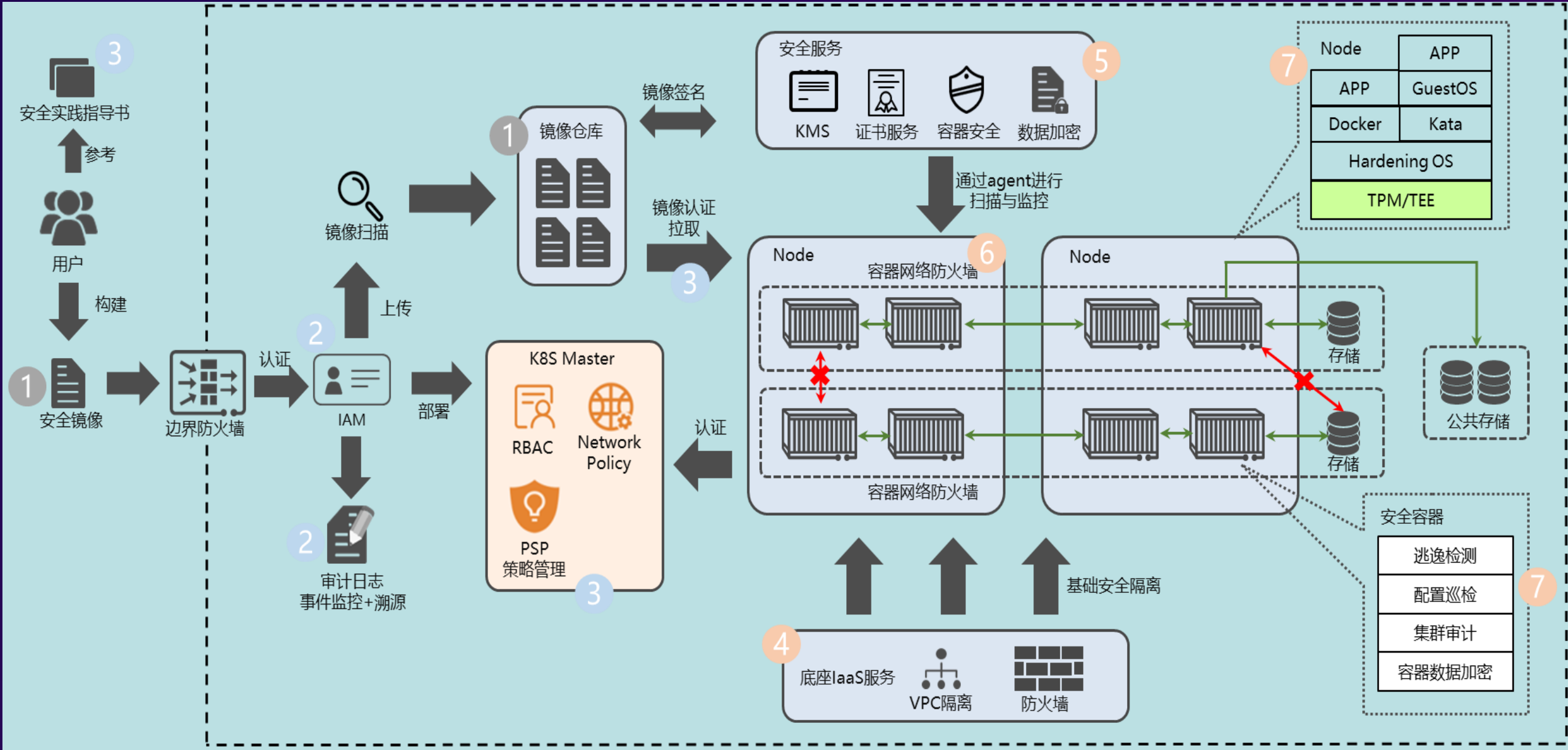
CNCF landscape安全项目及工具示意图



腾讯云容器安全服务（TCSS）架构图



华为云容器安全方案架构图

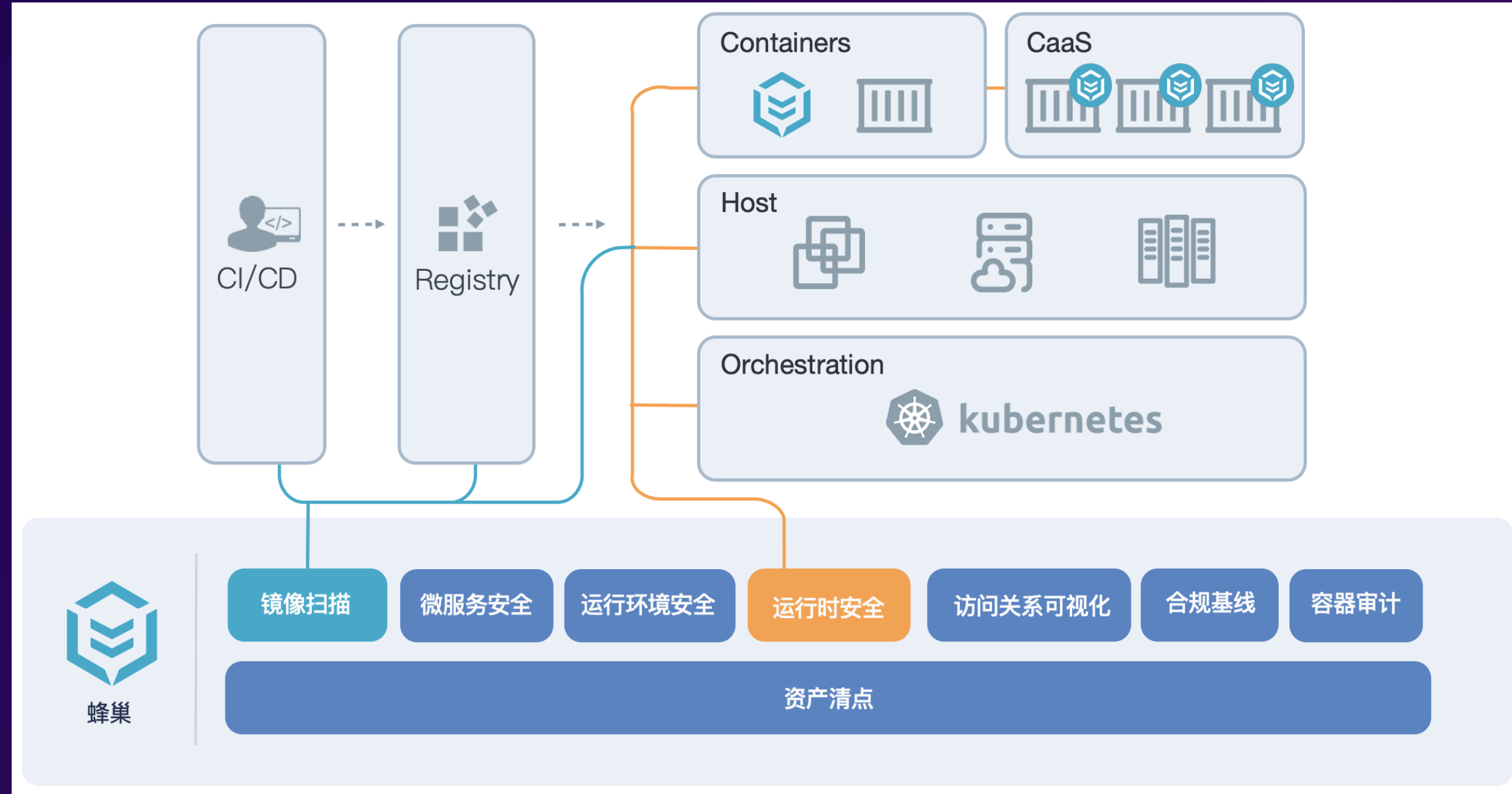


阿里云ACK 容器服务安全体系架构图



数据来源：《云原生架构安全白皮书（2021年）》

青藤云安全蜂巢容器安全产品架构图



小佑科技镜界容器安全防护平台架构图



中国信通院云原生安全工作概述

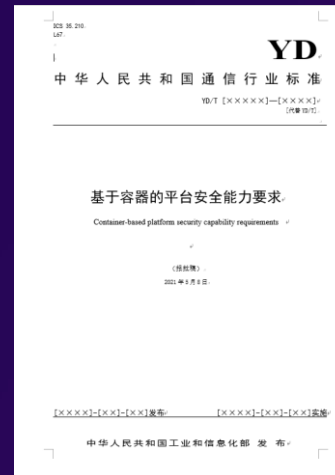
云原生安全工作组成立

2020.10，云原生产业大会（2020年）
首批成员单位：中国信通院、阿里云、
华为云、腾讯云、奇安信、绿盟、深信
服、青藤云



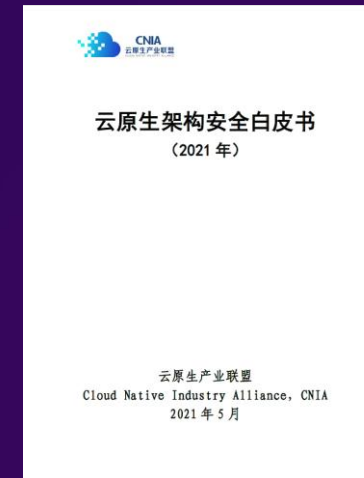
《云原生能力成熟度模型 第3部分：架构安全》 标准

2020.4，启动；
2020.5.6，TC1WG5第10次会议，立项
2021.4.26，TC1WG5第16次会议，征求意见
2021.5.18，工信部科技司立项



《基于容器的平台安全能力要求》标准

2019.8，启动；
2019.10.10，TC1WG5第8次会议，立项；
2019.11.19，TC1WG5第9次会议，征求意见；
2020.5.18，TC1WG5第11次会议，征求意见；
2020.11.23，TC1WG5第14次会议，送审；
2021.5.6，**报批。**



《云原生架构安全白皮书（2021年）》

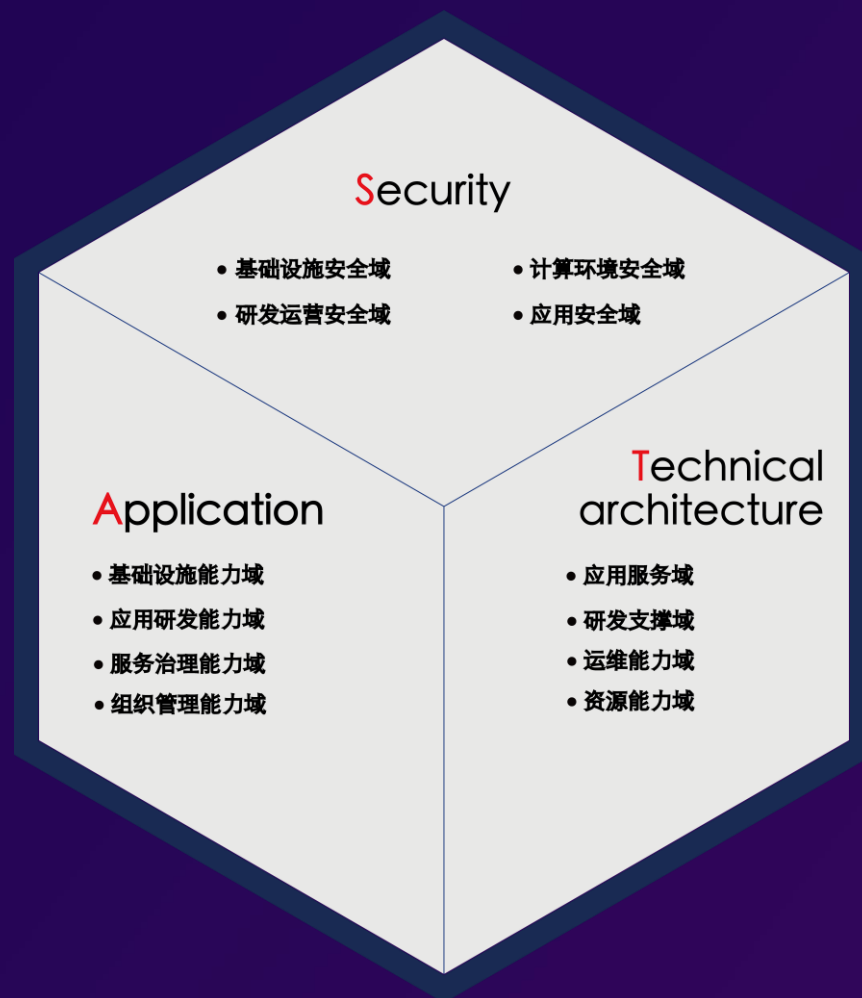
2020.10，启动；
期间召开5次研讨会，共形成6稿；
阿里云、华为云、腾讯云、百度、小佑科技、青藤
云、绿盟、奇安信、中国移动等18家企业参与；
2021.5.26云原生产业大会，**发布。**

- 1 云计算进入全面云原生时代
- 2 云原生安全威胁全面显现
- 3 构建自底向上的云原生安全防护体系
- 4 云原生安全发展趋势
- 5 云原生安全成熟度标准体系

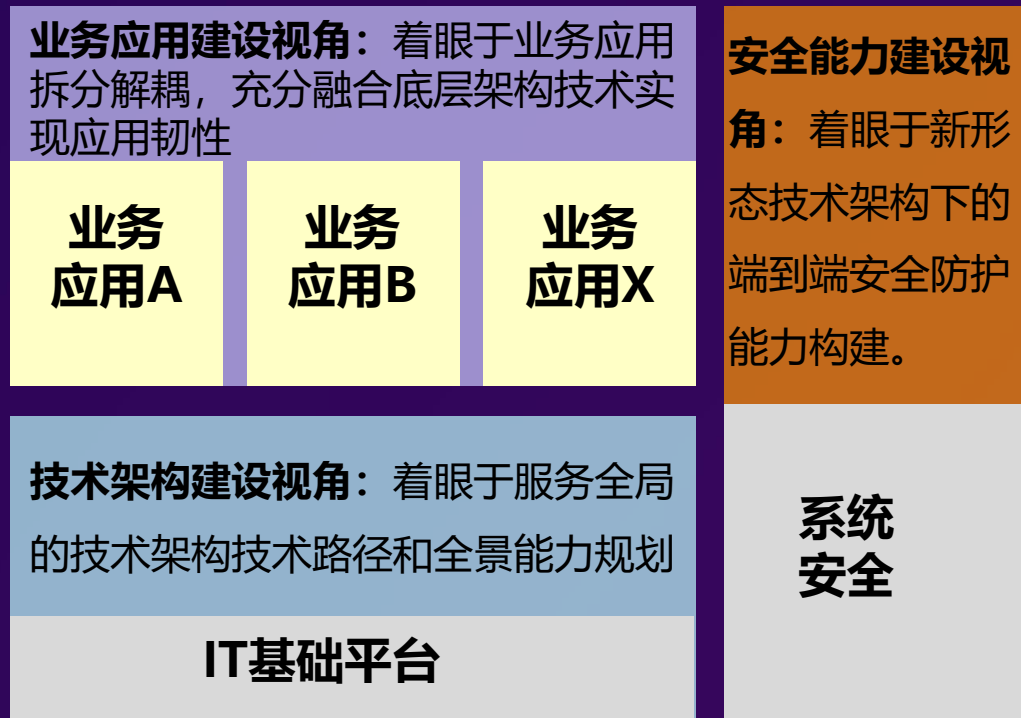
CNMM-TAS（云原生成熟度体系）：能力魔方和特性雷达立体展示成熟程度

一个体系，三个视角，五个特性，构造覆盖云原生架构、应用和安全的体系化**能力魔方**。深度融合云原生技术特性，以百余项能力指标描绘弹性、高可用、自动化、自愈性和可观测性的**特性雷达**。

云原生治理成熟度能力魔方



三个视角



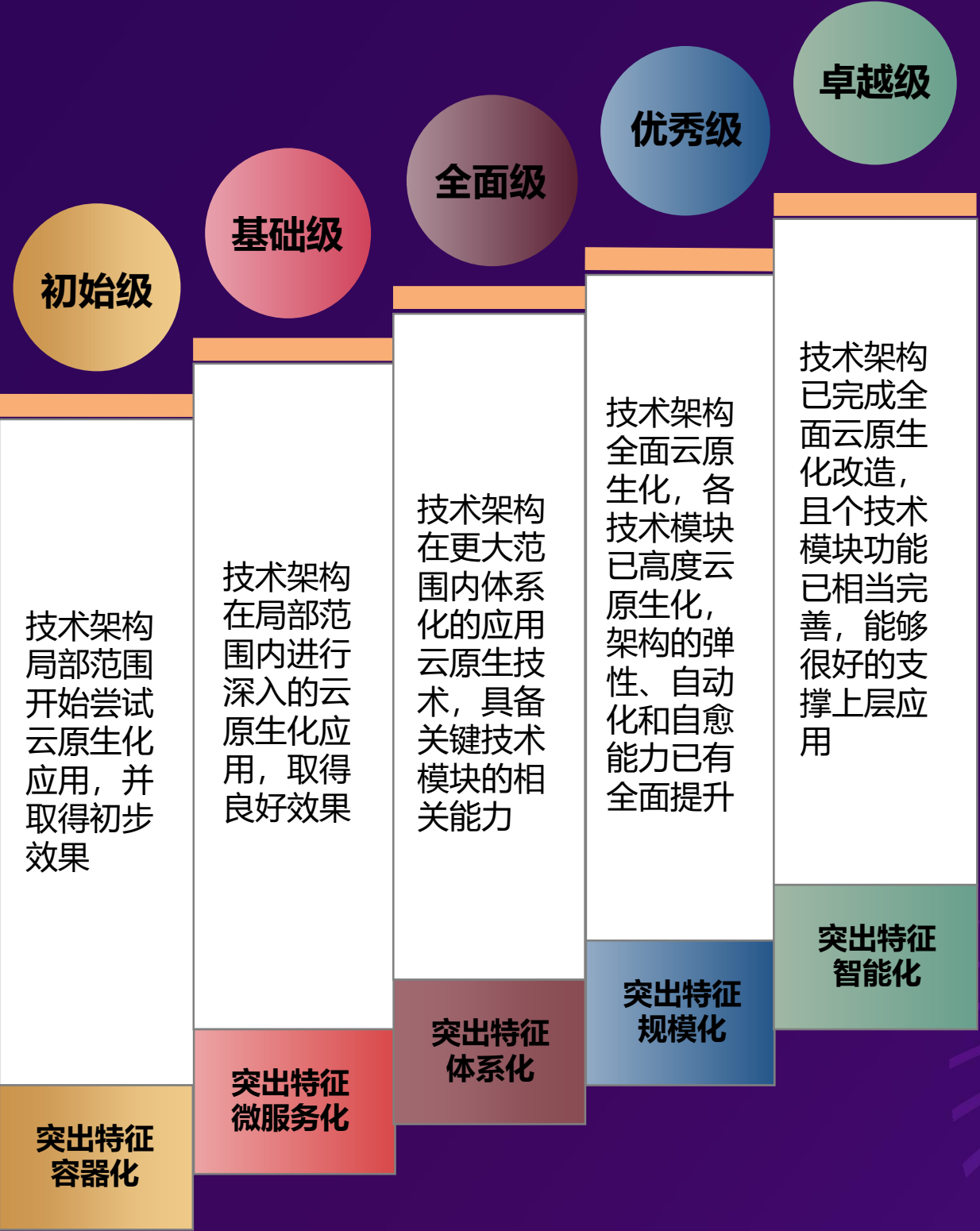
云原生TA特性雷达



CNMM-TAS（技术架构）：企业数字化韧性的自检标尺和建设指南

《云原生能力成熟度模型 第1部分：技术架构》涵盖4个能力域、12个过程域、41个能力子项，168个细分能力要求，能够帮助用户快速对照定位技术架构水平，并根据自身业务需求结合模型高阶能力定制技术架构演进方向。

技术架构成熟度												
能力域	资源能力域				运维能力域			研发支撑域		应用服务域		
过程域	计算环境	网络环境	存储环境	融合调度	高可用	可观测性	运维	开发	测试	中间件	应用治理	编排
能力子项	资源管理	网络互通	存储管理	调度算法	应用高可用	日志	自动化程度	变更管理	测试工具	共享化	服务化	分发部署范围
	运行时管理	网络形态	性能	调度效率	容灾设计	运维指标	监控告警	制品管理	测试数据管理	服务化	治理方式	自动化程度
	托管程度	网络策略	扩展性		组件服务化	链路追踪		云IDE	全链路压测	服务开发	治理粒度	
	弹性程度	网络性能	存储调度								治理能力	
	部署形态		可用性								APM	
											性能影响	
云原生特性	弹性											
	高可用											
	自愈性											
	可观测性											
	自动化											



CNMM-TAS（业务应用）：应用与技术融合使用的指引

《云原生能力成熟度模型 第2部分：业务应用》覆盖4个能力域，17个过程域，全方位诊断云原生业务应用综合成熟度水平，并结合弹性、高可用、自愈、可观测性和自动化等五大云原生应用特性成熟度，从业务应用视角为项目团队指引能力提升方向，更好地匹配业务应用发展需求。

应用架构持续演进，应用全面实现弹性、高可用、服务自愈、可观测性以及自动化和智能化交付

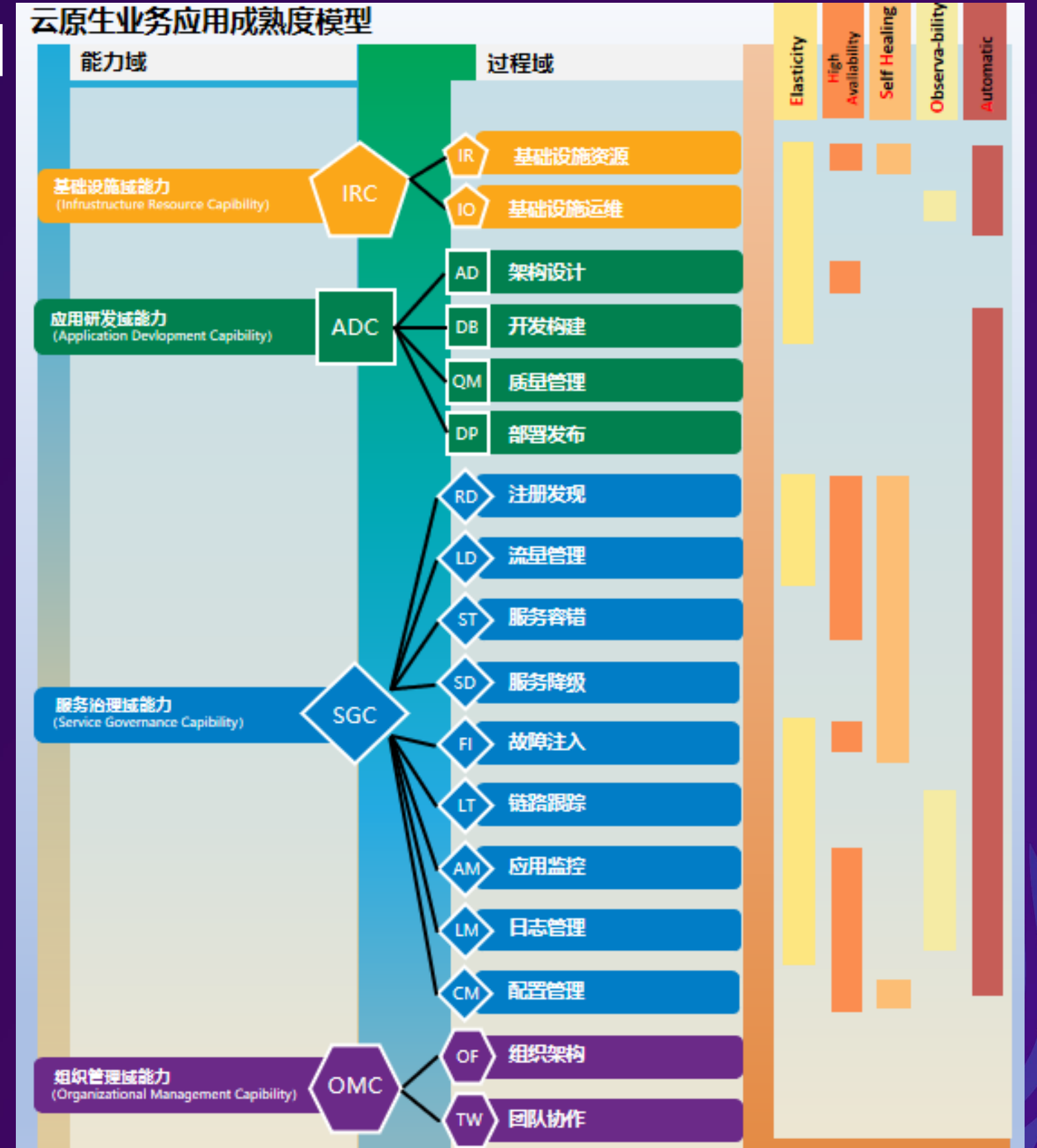
应用架构服务化改造开始，应用具备一定的弹性和高可用，实现多维度的应用监控

未实现任何云化改造，完全基于单体应用架构



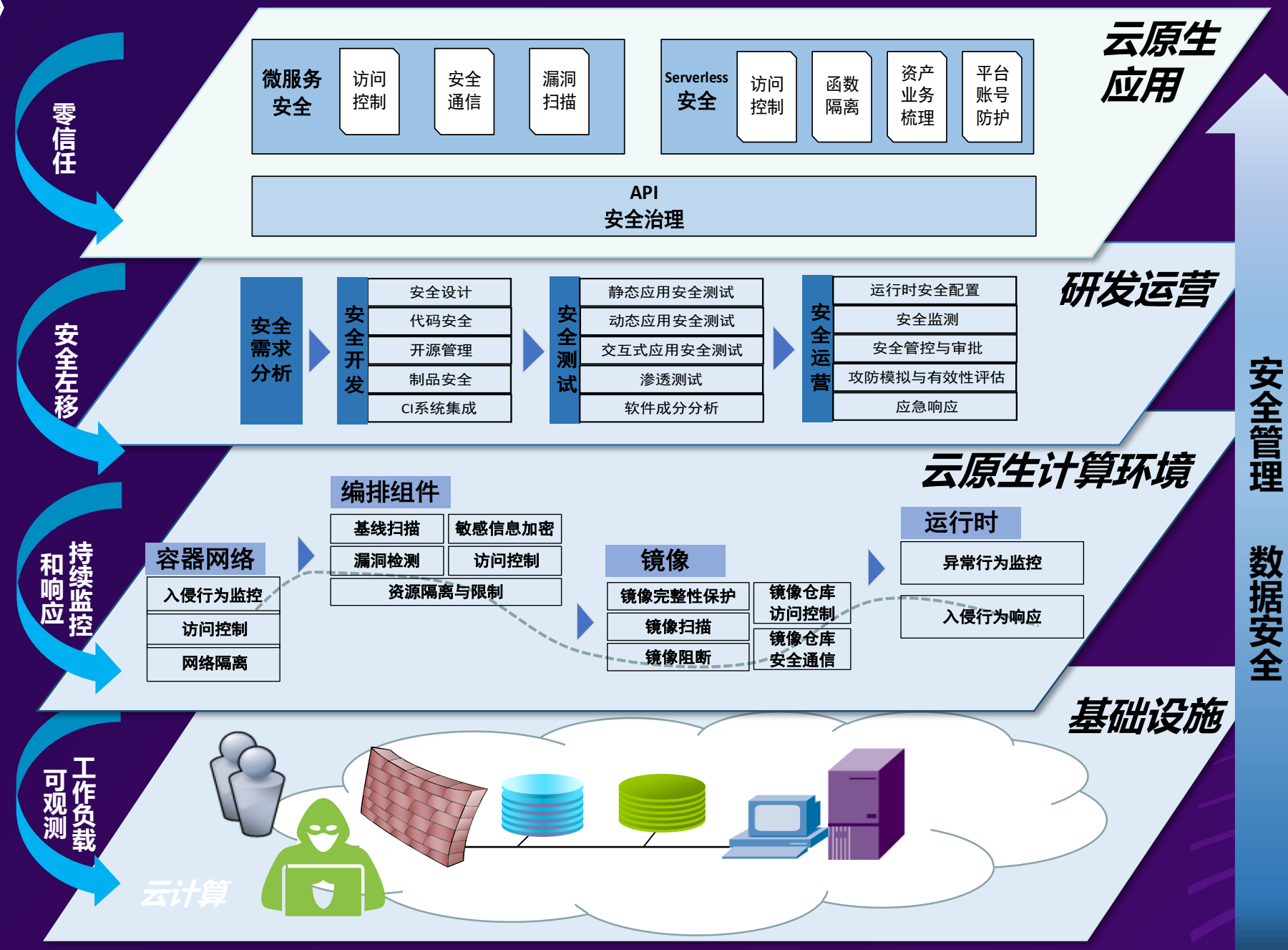
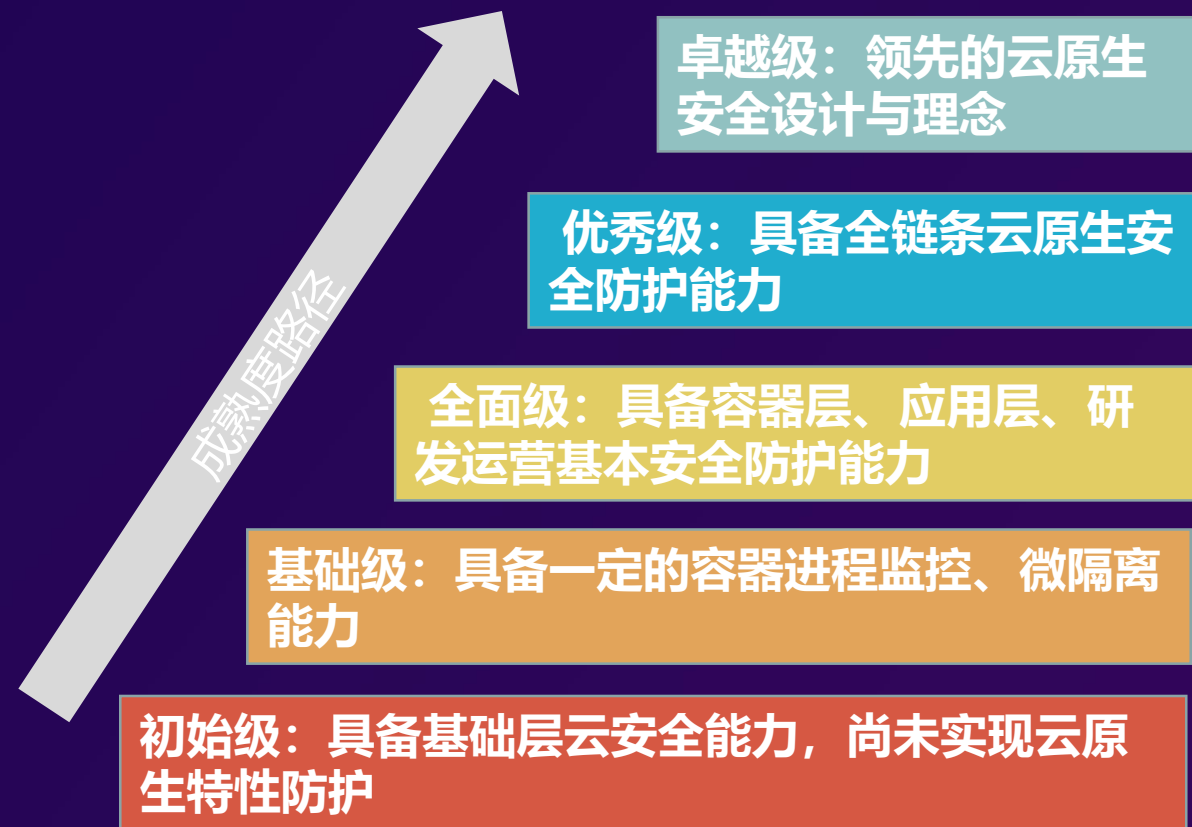
应用架构服务化改造基本完成，充分享受云原生生态，应用具备弹性、高可用，基本实现服务自愈，可观测性以及自动化

基于分布式应用架构，应用服务具备有限的弹性和容灾能力



CNMM-TAS（架构安全）：架构安全防护能力建设规范

《云原生能力成熟度模型 第3部分：架构安全》
六大子项、四大理念，打造云原生架构安全标准体系；涵盖基础设施安全、云计算环境安全、研发运营安全、云原生应用安全、数据安全、安全管理全链条、全生命周期安全防护能力。



云原生安全成熟度标准分级依据

第5级（卓越级）：具备**超前的**云原生安全防护能力，具备**自我提高和引领级**的云原生安全防护体系，有**丰富的项目经验**；能够对云原生恶意攻击行为进行**预先研究和预判告警**，具备**自动化监测**和**威胁自愈**能力。

第4级（先进级）：具备**完备的全链条**云原生安全防护能力，具备系统级云原生安全防护体系，有**较丰富的项目经验**；能够防护拥有**较丰富资源**的威胁发起的恶意攻击，能够**及时发现、检测较完备的攻击行为**，并采用自动化手段做出应对。

第3级（成熟级/系统级）：具备**较完整**的云原生安全防护能力，具备**多个模块和部分系统级**云原生安全防护体系，有**多个项目经验**；能够防护拥有**一定量资源**的威胁发起的恶意攻击，能够**发现、检测常见的攻击行为**并做出应对。

第2级（基础级/模块级）：具备**基础级**云原生安全防护能力、具备**模块级**的云原生安全防护体系；能够防护拥有**少量资源**的威胁发起的恶意攻击，并对**部分攻击行为**做出应对。

第1级（零级/概念级）：具备传统云平台安全技术能力，具备**概念级**的云原生安全防护能力；



感谢聆听
Thanks

● 2021首届-西部云安全峰会
Western China Cloud Security Summit 2021